



网络安全技术及应用

(第5版, 慕课微课版, 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编

 **机械工业出版社**
CHINA MACHINE PRESS

第8章 防火墙常用技术



回顾

计算机病毒（Computer Virus）在《**中华人民共和国计算机信息系统安全保护条例**》中被明确**定义**为：是指编制者在计算机程序中插入的破坏系统功能或破坏数据，影响系统使用并能够自我复制的一组指令或程序代码。

手机病毒是一种具有传染性、破坏性的手机程序。实质上同计算机病毒基本一样，以后统称为**网络病毒**。

回顾

计算机病毒发展主要经历了五个重要阶段。

(1) 原始病毒阶段（第一阶段）

(2) 混合型病毒阶段（第二阶段）

(3) 多态性病毒阶段（第三阶段）

(4) 网络病毒阶段（第四阶段）

(5) 主动攻击型病毒阶段（第五阶段）

回顾

常用命名方式由多个前缀与后缀组合，中间以点“.”分隔，**一般格式**为：[病毒前缀].[病毒名].[病毒后缀]。

1) 卡巴斯基（俄罗斯）的命名：一般情况，卡巴斯基的病毒名分为四个部分，依次用“.”分隔，第1部分表示计算机病毒的主类型名及子类型名，第2部分表示计算机病毒运行的平台，第3部分表示计算机病毒所属家族名，第4部分是变种名。

2) 瑞星（中国）的命名：一般情况下，瑞星病毒名分为五个部分，依次用“.”分隔，第1部分表示计算机病毒的主类型名。第2部分是子类型名，第3部分是病毒运行的平台，第4部分是病毒所属的家族名，第5部分是变种名。

回顾

■ 计算机及手机病毒的特点

根据对病毒的产生、传播和破坏行为的分析, 概括为7个**主要特点**

1. 传染性
2. 隐蔽性
3. 潜伏性
4. 非授权可执行性
5. 触发及控制性
6. 影响破坏性
7. 多态不可预见性

回顾

计算机病毒主要构成，有3个单元构成：

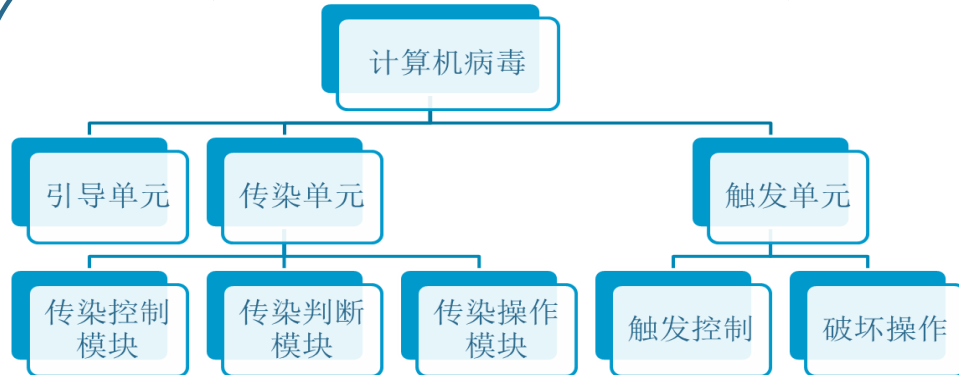
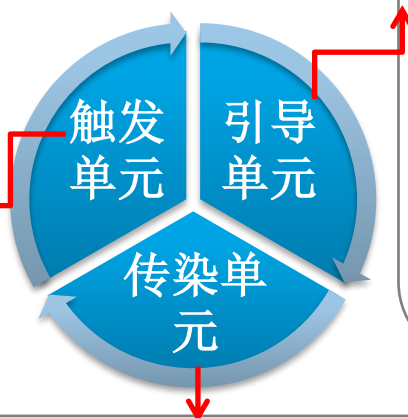


图7-1 计算机病毒的主要构成

3) 由两个部分构成，一是触发控制部分，二是影响破坏操作部分。



1) 也称**潜伏机制模块**，具有初始化、隐藏和捕捉功能。可将病毒加载到内存中，并保护其存储，以防被其他程序覆盖，同时修改一些中断及高端内存、保存原中断系统参数，为传播做准备。

2) 是病毒程序的**核心**，主要**功能**是传播病毒，由三个部分构成，传染控制模块、传染判断模块、传染操作模块

回顾

■ 计算机病毒的检测

特征代码法：采集已知病毒样本，打开被检测文件，在文件搜索中检查文件是否含有病毒数据库中的病毒特征代码；因为特征代码与病毒一一对应，如果发现病毒特征代码，便可以断定被查文件中患有何种病毒。

行为检测法：利用病毒的特有行为特征对病毒进行监测的方法称为行为监测法。

校验和法：计算正常文件内容的校验和，将该校验和写入文件或写入其他文件中保存。在文件使用过程中，定期或每次使用文件前，检查文件现在内容并算出校验和，用算出的校验和与原来保存的校验和对比是否一致，因而可以发现文件是否感染，这种方法叫校验和法。

启发式扫描法

软件模拟法



回顾

■ 常见病毒的清除方法

将感染病毒的文件的病毒代码摘除，使之恢复成可以正常运行的健康文件，称为**病毒的清除**，有时称为**对象恢复**。

对一般常见的病毒，通常利用杀毒软件即可清除。



若单个可执行文件的病毒不能被清除，可将其删除重新安装。



若多数系统文件和应用程序被破坏，且中毒较重，删除后重新安装。



当感染的是关键数据文件，或受破坏较重，可请专业人员进行清除和数据恢复。

杀毒后重启，再用查杀病毒软件检查系统，并确认完全恢复正常。

目 录

1

8.1 防火墙概述

2

8.2 防火墙的类型

3

8.3 防火墙的主要应用

4

8.4 本章小节



目 录

教学目标

- 掌握防火墙的基本概念和作用 **重点**
- 掌握防火墙常用的主要功能特点及缺陷 **重点**
- 理解防火墙的不同分类方法和应用
- 掌握SYN Flood攻击方式及用防火墙阻止其攻击的方法
- 掌握常用防火墙安全应用实验



8.1 防火墙概述

8.1.1 防火墙的概念和功能

案例8-1

某些单位内部无法访问外部某些网址，一般情况下是因为在单位内部网络上安装了防火墙。**安装防火墙可以过滤掉不安全的信息。**内网一旦遇到不良信息或者有风险的信息，防火墙会进行拦截并及时发出警报提示管理员。按需求不同防火墙具有不同功能，某单位以前的内部邮件系统经常接收大量垃圾邮件，在安装具有反垃圾邮件功能的防火墙后，该单位用户接收的垃圾邮件大大减少。

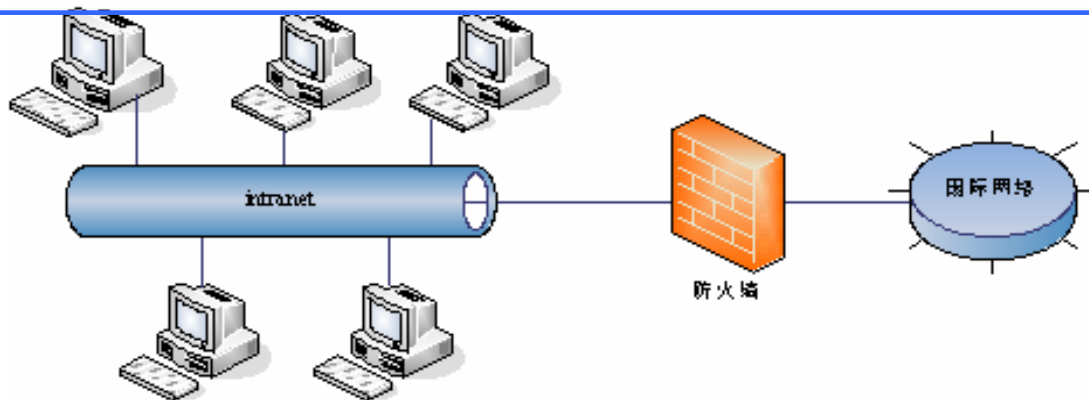
8.1 防火墙概述

8.1.1 防火墙的概念和功能

1. 防火墙的概念和部署

防火墙 (firewall) 是一个由软件 and 硬件设备组成、在内部网和外部网之间、专用网与公共网之间通过隔离过滤技术构造的保护屏障，使内部网与外部网之间建立起一个安全网关，以保护内部网络不受非法用户的侵入，是必不可少的解决网络安全问题的设备之一。

防火墙是内、外部网络通信安全过滤的主要途径，能够根据制定的访问规则对流经它的的信息进行监控和审查。网络防火墙的部署结构如图 8-1 所示。



8.1 防火墙概述

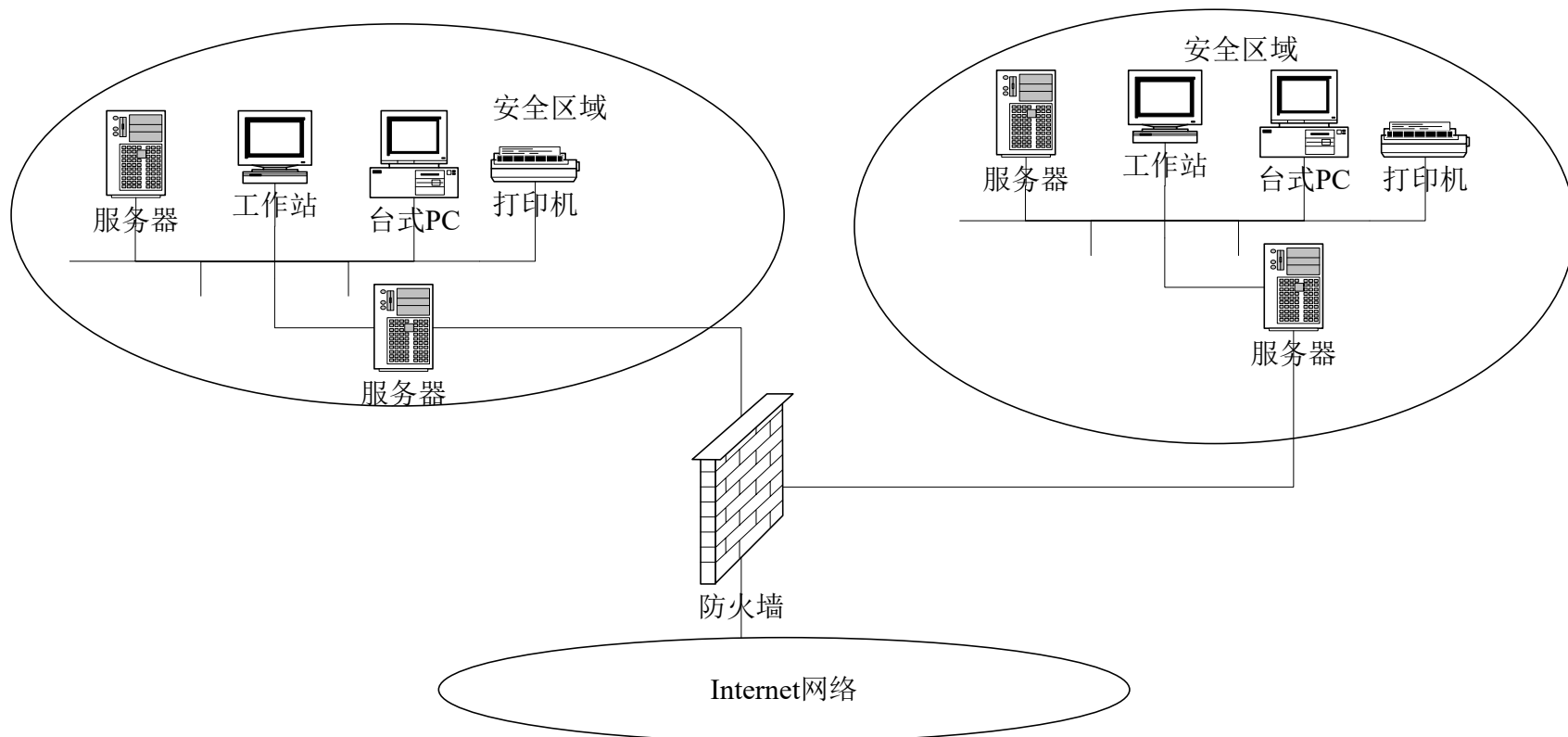
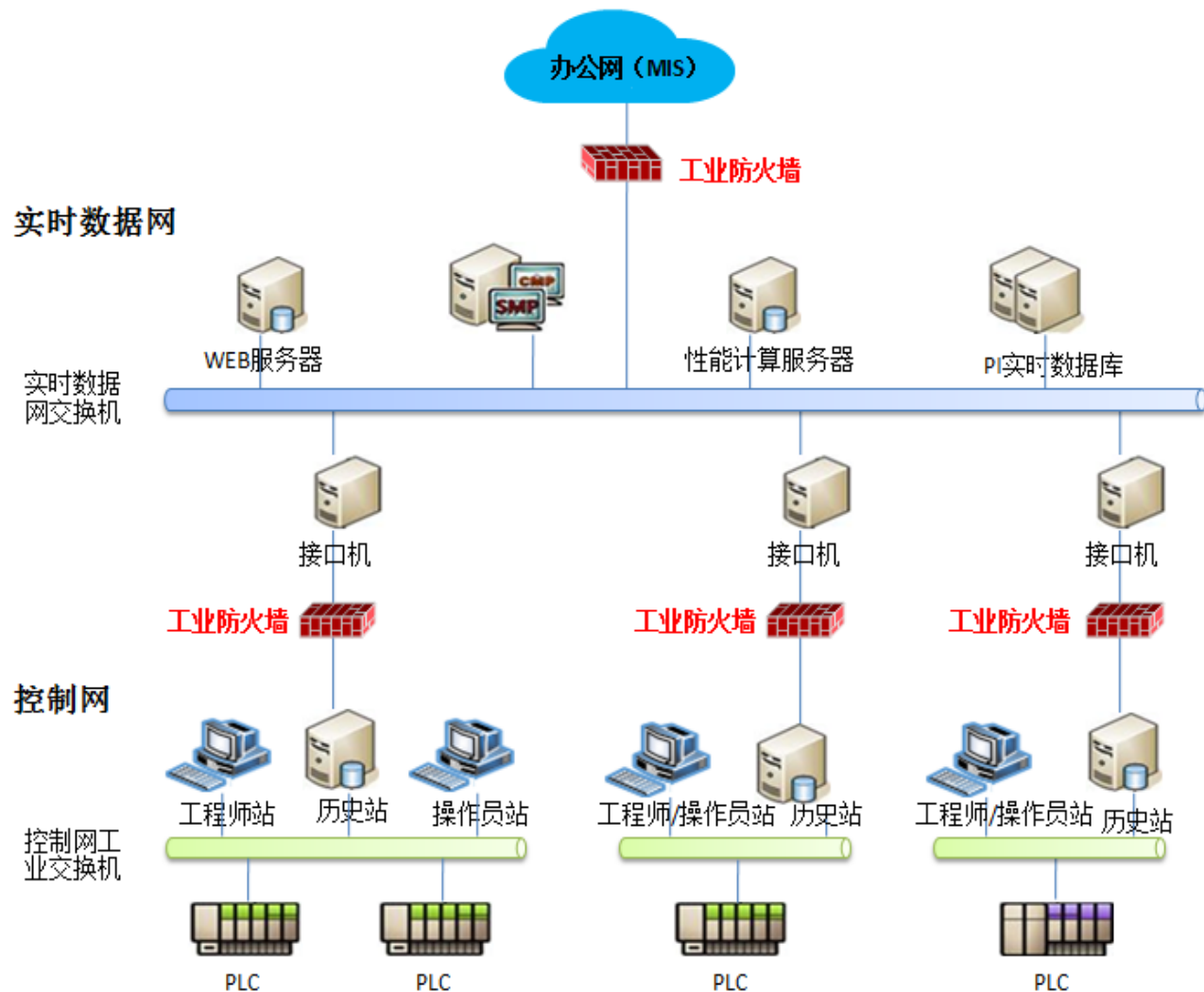


图8-1 网络防火墙的部署结构

8.1 防火墙概述



图例:  工业防火墙

工业防火墙的部署结构

8.1 防火墙概述

传统的防火墙通常基于**访问控制列表 (ACL)** 进行包过滤，位于内部专用网的入口处，所以也俗称“**边界防火墙**”。

随着网络技术的发展，防火墙技术也得到了发展，出现了一些新的防火墙技术，如**电路级网关技术（会话层）**、**应用网关技术（应用层）**和**动态包过滤技术（网络/传输层）**。在实际运用中，这些技术差别非常大，有的工作在 OSI 参考模式的网络层，有的工作在传输层，还有的工作在教育层。

除了**访问控制**功能外，现在大多数的防火墙制造商在自己的设备上还集成了其他安全技术，如 **NAT 和 VPN、病毒防护**等。

8.1 防火墙概述

Subjects \ Objects		O ₁	O ₂	O ₃
CL	S ₁	Read/Writs		
	S ₂	Execute	Write	
	S ₃			Read

ACL

访问控制矩阵、访问控制列表、能力表

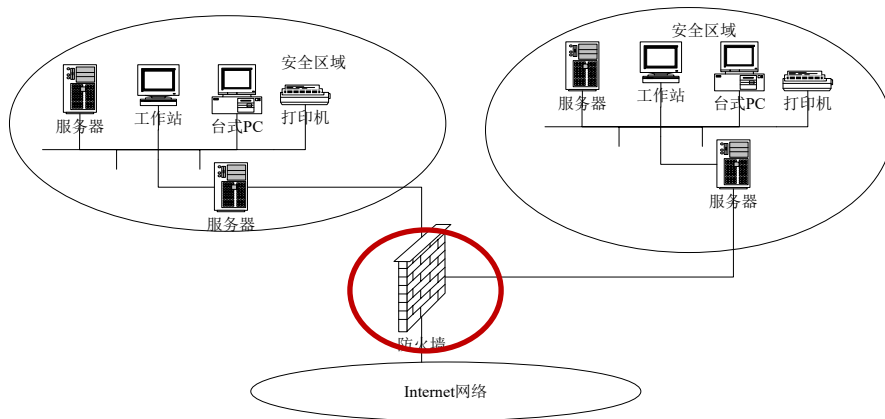
8.1 防火墙概述

2. 防火墙的主要功能

过滤防御系统

实际上，防火墙其实是一个分离器、限制器或分析器，它能够有效监控内部网络和外部网络之间的所有活动，主要功能如下：

(1) 建立一个**集中的监视点**。防火墙位于两个或多个网络之间，使用包过滤技术对所有流经它的数据包都进行过滤和检查，这些检查点被称为“**阻塞点**”。通过强制所有进出流量通过阻塞点，网络管理员可以集中在较少的地方实现安全的目的。



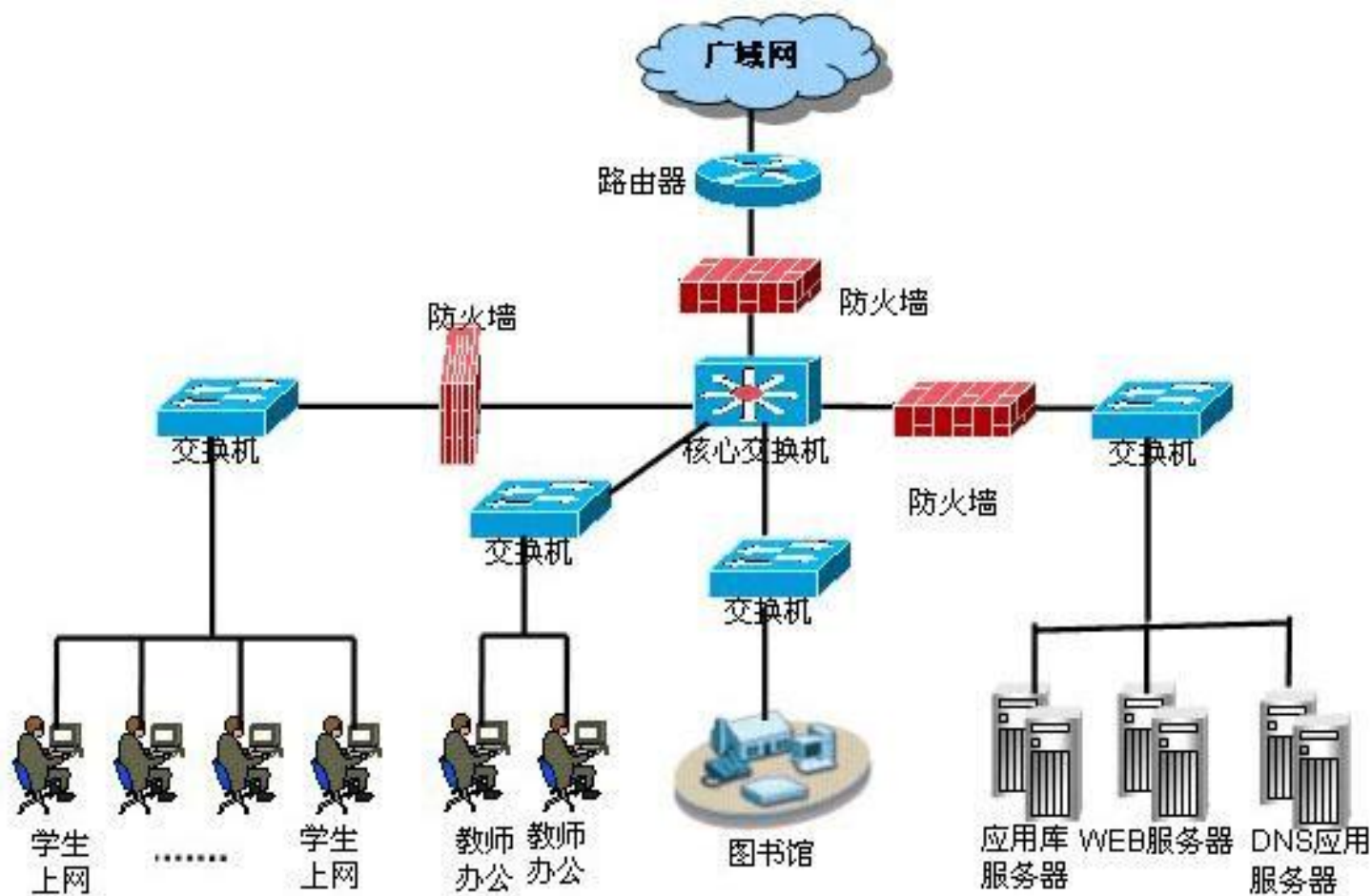
8.1 防火墙概述

2. 防火墙的主要功能

(2) **隔离**内、外网络，**保护**内部网络。这是防火墙的**基本功能**，通过隔离内、外网络，可以防止非法用户进入内部网络，并能有效防止邮件炸弹、蠕虫病毒、宏病毒的攻击。

(3) **强化网络安全策略**。通过**以防火墙为中心的安全方案配置**，能将所有的安全软件(如**口令、加密、身份认证、审计**等)配置在防火墙上，例如在防火墙上实现 AAA 认证。与将网络安全问题分散在各个主机上相比，防火墙的集中安全管理更为经济。

8.1 防火墙概述



校园网网络总拓扑结构图

8.1 防火墙概述

2. 防火墙的主要功能

(4) 有效**记录和审计**内、外网络之间的活动。内、外网络之间的数据包必须经过防火墙，防火墙可对这些数据包进行记录并写进日志系统，同时对使用情况进行数据统计。当发生可疑动作时，防火墙能进行适当报警，并提供网络是否受到监测和攻击的详细信息。

以上四个功能为防火墙基本功能。

8.1 防火墙概述

2. 防火墙的主要功能

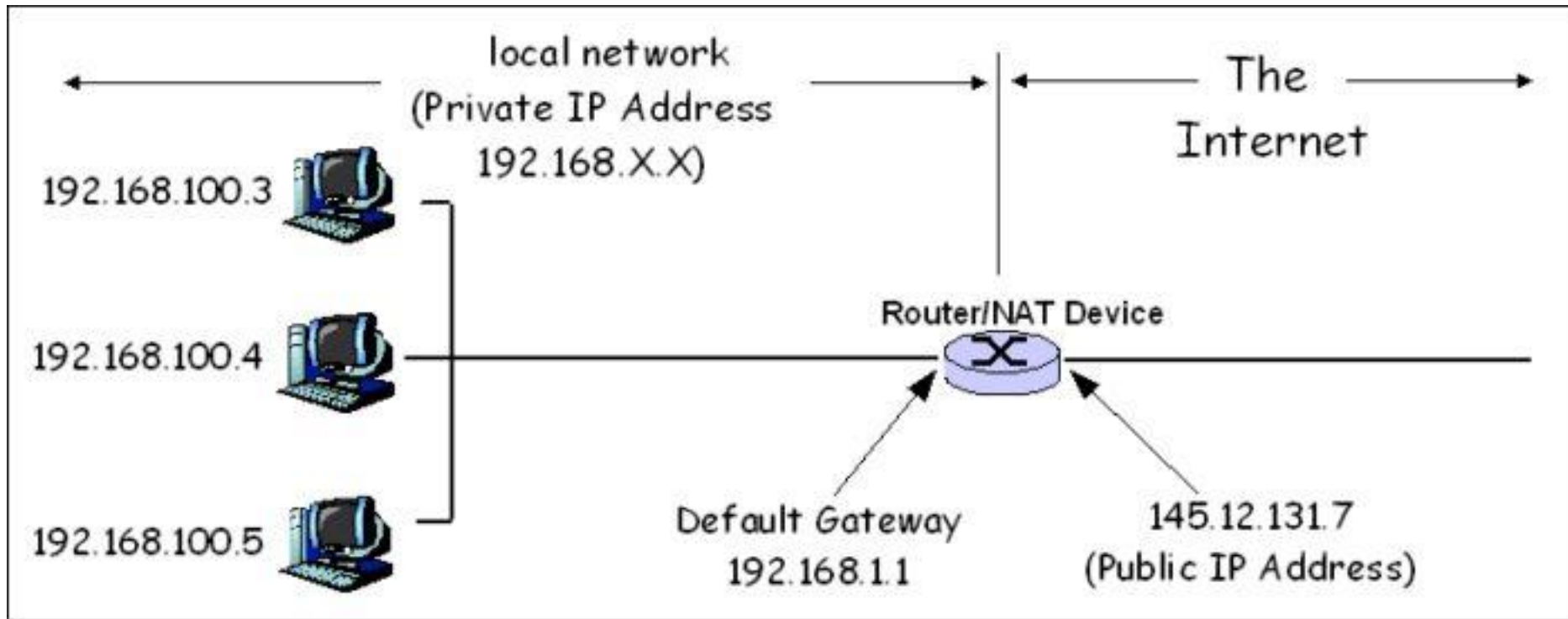
(5) **代理转发**。代理技术使得防火墙将用户的访问请求变成由防火墙代为转发，使得外部网络无法查看内部网络的结构，也无法直接访问内部网络主机。在防火墙代理技术中，第一种是**透明代理**，内部网络用户在访问外部网络的时候，无须更改任何配置，防火墙就像透明的一样；第二种是**传统代理**，其工作原理与透明代理相似，所不同的是它需要在客户端设置代理服务器。与包过滤技术相比，使用代理可以提供**更加细致的过滤**，但是实现过程复杂且速度较慢。

8.1 防火墙概述

2. 防火墙的主要功能

(6) **网络地址转换(NAT)**。网络地址转换可以屏蔽内部网络的 IP 地址，对内部网络用户起到**保护**作用；同时可以用来**缓解 IPv4 的 IP 地址资源短缺**问题。在内部网络与外部网络进行的网络地址转换过程中，当防火墙收到内部网络访问外部网络的请求时，防火墙对收到的内部访问请求进行验证，决定允许还是拒绝该访问请求通过，网络地址转换机制 NAT 将请求的源 IP 地址转换为一个公共地址，并将变动后的请求信息转发往目的地。当从目的地返回的响应信息到达防火墙接口时，NAT 将响应数据包中的目的地址转换为发出请求的内联网络主机的 IP 地址，然后将该响应数据包发往发出请求的内部网络主机。

8.1 防火墙概述





8.1 防火墙概述

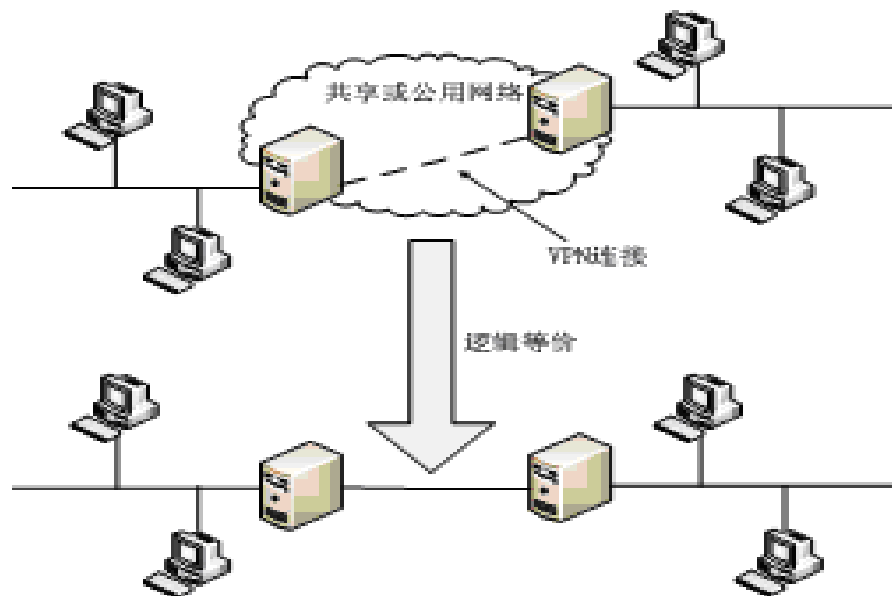
2. 防火墙的主要功能

(7) **虚拟专用网 (VPN)**。VPN 在不安全的公共网络上建立一个专用网络来进行信息的安全传递，目前已经成为在线交换信息的最安全的方式之一。VPN 技术基本上已经是主流防火墙的标准配置，一般防火墙都支持 VPN 加密标准，并提供基于硬件的加解密功能。

8.1 防火墙概述

VPN

VPN可通过特殊加密通信协议为**Internet**上异地企事业单位内网之间建立一条专用通信线路，而无需铺设物理线路。**系统结构**如图2-3所示。



VPN系统结构

2.2 虚拟专用网VPN技术

VPN特点

1) **安全性高**。VPN使用通信协议、身份验证和数据加密等技术，保证其网络通信传输的安全性。客户机先向VPN服务器发出请求，响应请求后要求输入身份认证信息，之后客户机发送认证信息，服务器通过数据库检查认证该用户的远程访问权限，对通过用户服务器接收并连接，身份验证过程中所使用的公有密钥都需要加密。

2) **费用低应用广**。利用VPN远程用户或机构，都可以通过Internet进行访问，比传统网络访问方式的费用少很多，可节省购买、管理和维护通信设备的费用且应用广泛。

3) **管理便利**。构建VPN只需很少专用的网络设备及线路，且网络管理非常简便。对于远程访问的企事业单位或用户，只需要通过公用网络端口或Internet即可进入机构网络，网络管理如同使用微信群其主要工作由公用网负责。





2.2 虚拟专用网VPN技术

VPN特点

4) **灵活性强**。**VPN**支持通过各种网络的任何类型的数据流，支持多种类型的传输媒介，并可以同时传输图像、语音和其他数据等需求。

5) **服务质量好**。可满足机构不同等级的服务质量**QoS**需求，各种用户和业务对**QoS**要求差别较大，如对移动用户，提供广泛连接和覆盖性是保证**VPN**服务的一个主要因素。对于拥有众多分支机构的专线**VPN**，交互式内网应用要求网络具有良好的稳定性，视频传输等应用对网络提出了更具体的要求，如网络时延及误码率等，这些网络应用都要求按其需要提供不同等级的服务质量。

8.1 防火墙概述

3 防火墙的特性

目前，防火墙需要具备以下的技术和功能特性，才能成为企事业单位和个人用户欢迎的防火墙产品：

（1）安全、成熟、国际领先的特性，具有专有的硬件平台和操作系统平台，采用**高性能的全状态检测(Stateful Inspection)技术**，具有优异的管理功能，提供优异的 **GUI** 管理界面。

（2）支持多种用户认证类型和多种认证机制，支持用户分组，并支持分组认证和授权，支持内容过滤，支持动态和静态地址转换 **NAT**。

8.1 防火墙概述

3 防火墙的特性

(3) 支持高可用性，单台防火墙的故障不能影响系统的正常运行，支持本地管理和远程管理，支持日志管理和对日志的统计分析，具备实时告警功能，在不影响性能的情况下，支持较大数量连接，在保持足够的性能指标的前提下，能够提供尽量丰富的功能。

(4) 可以划分很多不同安全级别的区域，相同安全级别可控制是否相互通信，支持在线升级，支持虚拟防火墙及对虚拟防火墙的资源限制等功能，防火墙能够与入侵检测系统互动。

8.1 防火墙概述

4 防火墙的主要缺陷

防火墙是网络上使用最多的安全设备，是网络安全的基石。但防火墙并不是万能的其功能和性能都有一定的**局限性**，只能满足系统与网络特定的安全需求。防火墙的主要缺陷有以下几个方面：

（1）**无法防范不经由防火墙的攻击**。如果数据绕过防火墙，就无法检查。例如，内部网络用户直接从 **Internet** 服务提供商那里购置 **SLIP** 或 **PPP** 连接，就绕过了防火墙系统所提供的安全保护，从而造成了一种潜在的后门攻击渠道。入侵者就可以伪造数据绕过防火墙对这个敞开的后门进行攻击。

（2）是一种**被动**安全策略执行设备。即对于新的未知攻击或者策略如果配置有误，防火墙就无能为力了。

8.1 防火墙概述

4 防火墙的主要缺陷

(3) 不能防止利用**标准网络协议中的缺陷**进行的攻击。一旦防火墙允许某些标准网络协议，就不能防止利用协议缺陷的攻击。例如 **DoS** 或 **DDoS** 进行的攻击。

(4) 不能防止利用**服务器系统漏洞**进行的攻击。防火墙不能阻止黑客通过防火墙准许的访问端口对该服务器漏洞进行的攻击。

(5) 不能防止**数据驱动式的攻击**。当有些表面看起来无害的数据邮寄或复制到内部网的主机上并被执行时，可能会发生数据驱动式的攻击。

(6) **无法保证准许服务的安全性**。防火墙可以准许某项服务，但不能保证该服务的安全性。准许服务的安全性问题应通过应用安全解决。

8.1 防火墙概述

4 防火墙的主要缺陷

(7) 不能防止**本身的安全漏洞**威胁。防火墙有时无法保护自己。目前没有厂商能绝对保证自己的防火墙产品不存在安全漏洞，所以，对防火墙也必须提供某种安全保护。

(8) 不能防止**感染了病毒的软件或文件传输**。防火墙本身不具备查杀病毒的功能，即使有些防火墙集成了第三方的防病毒软件，也没有一种软件可以查杀所有病毒。

此外，防火墙在性能上不具备**实时监控入侵**的能力，其**功能与速度成反比**。防火墙的功能越多，对 CPU 和内存的消耗越大，速度越慢。管理上，**人为因素**对防火墙安全的影响也很大。因此，仅仅依靠现有的防火墙技术，是远远不够的。



8.2 防火墙的类型

以防火墙的软硬件形式分类

1. 软件防火墙

软件防火墙运行于特定的计算机上，它需要客户预先安装好相应的计算机操作系统，一般来说这台计算机就是整个网络的网关，俗称“**个人防火墙**”。软件防火墙就像其他的软件产品一样需要先计算机上安装并做好配置才可以使用。防火墙厂商中做网络版软件防火墙最出名的莫过于以色列的**Checkpoint** 公司。使用这类防火墙，需要网管熟悉所工作的操作系统平台。

8.2 防火墙的类型

以防火墙的软硬件形式分类

2. 硬件防火墙

硬件防火墙是针对芯片级防火墙而言的。其与芯片级防火墙最大的差别在于是否基于专用的硬件平台。目前市场上**大多数**防火墙都是这种所谓的硬件防火墙，都**基于 PC 架构**。在这些 **PC 架构**计算机上运行一些**经过裁剪和简化的操作系统**，最常用的有老版本的 **UNIX、Linux 和 FreeBSD** 系统。值得注意的是，由于此类防火墙采用的依然是别人的内核，因此依然会受到操作系统本身的安全性影响。

传统硬件防火墙一般至少应具备 **3个端口**，分别接**内网、外网和 DMZ 区**(无戒备区，非安全系统与安全系统之间的缓冲区)，现在一些新的硬件防火墙往往扩展了端口，常见四端口防火墙一般将第 **4 个端口**作为**配置口、管理端口**，很多防火墙还可以进一步扩展端口数目。

8.2 防火墙的类型

以防火墙的软硬件形式分类

3. 芯片级防火墙

芯片级防火墙基于专门的硬件平台，没有操作系统。专有的 **ASIC** 芯片（用于供专门应用的集成电路芯片技术）使得它们比其他种类的防火墙速度更快、处理能力更强、性能更高。这类防火墙，国外知名的厂商有Juniper、Cisco、Checkpoint 等，国内知名的厂商有华为、天融信、深信服等。这类防火墙由于是专用操作系统，因此**防火墙本身的漏洞比较少**，不过价格相对比较高昂。

	CISCO ASA5520-BUN-K9 设备类型: VPN防火墙 并发连接数: 280000 网络端口: 千兆以太网端口×4、 安全过墙带宽: 225Mbps 加入对比 +	网络吞吐量: 450Mbps 用户数限制: 无用户数限制 入侵检测: DoS 管理: 思科安全管理 更多参数>> 评分: ★★★★★ 4.0 点评(2) 评测(1) 帖子(14)	¥2.8万 2013-04-19 90家商家报价 查询底价
	华为USG2210 设备类型: 安全网关 入侵检测: Dos,DDoS VPN支持: 支持 控制端口: Console口 加入对比 +	网络端口: 2GE Combo 管理: 支持命令行、WEB方式 安全标准: CE, ROHS, CB, UL, VC 其他性能: UTM 扩展槽 更多参数>> 评分: ★★★★★ 4.0 点评(5)	¥7800 2013-04-25 59家商家报价 查询底价
	华为USG5120 设备类型: 安全网关 入侵检测: DoS, DDoS VPN支持: 支持 其他性能: UTM 扩展槽位: 4MIC+ 加入对比 +	网络端口: 2GE Combo+2 GE 管理: 支持命令行、WEB方式 安全标准: CE, ROHS, CB, UL, VC 处理器: 多核处理器 更多参数>> 评分: ★★★★★ 4.0 点评(2)	¥2.65万 2013-04-25 52家商家报价 查询底价

8.2 防火墙的类型

软件、硬件、芯片级防火墙对比

1. 定义与核心原理

类型	定义	核心原理
软件防火墙	安装在操作系统上的应用程序，依赖宿主机的资源运行。	通过软件规则过滤网络流量，基于主机的CPU和内存处理数据包。
硬件防火墙	独立物理设备，内置专用硬件和操作系统（如定制Linux或实时OS）。	专用硬件（如多核处理器）处理流量，独立于主机资源，部署在网络边界。
芯片级防火墙	基于专用芯片（如ASIC、NPU、FPGA）的硬件级解决方案，集成于网络设备或芯片中。	通过硬件加速处理流量，协议解析和过滤直接在芯片层级完成，实现超低延迟和高吞吐。

8.2 防火墙的类型

软件、硬件、芯片级防火墙对比

2. 性能对比

维度	软件防火墙	硬件防火墙	芯片级防火墙
吞吐量	低（依赖主机性能，通常<1 Gbps）	高（专用硬件，可达100 Gbps+）	极高（芯片加速，可达Tbps级）
延迟	较高（受操作系统调度影响）	低（专用硬件优化）	极低（硬件级处理，纳秒级延迟）
并发连接数	有限（受主机内存限制）	高（支持百万级连接）	极高（芯片缓存直接管理连接状态）
资源占用	高（占用CPU、内存）	无（独立设备）	无（独立芯片或模块）



8.2 防火墙的类型

软件、硬件、芯片级防火墙对比

3. 部署与适用场景

维度	软件防火墙	硬件防火墙	芯片级防火墙
部署位置	单台主机（如PC、服务器）	网络边界（如企业网关）	网络设备内部（如交换机、路由器、5G基站）
典型场景	- 个人电脑 - 小型服务器补充防护	- 企业网络边界 - 数据中心入口防护	- 超大规模数据中心 - 电信核心网 - 工业物联网
灵活性	高（可定制规则，适配不同OS）	中等（需配置设备策略）	低（依赖芯片设计，规则固化）

8.2 防火墙的类型

软件、硬件、芯片级防火墙对比

4. 成本与维护

维度	软件防火墙	硬件防火墙	芯片级防火墙
初期成本	低（免费或订阅制，如Windows防火墙）	高（设备采购+授权费）	极高（专用芯片研发/采购成本）
运维成本	高（需逐台维护）	中等（集中管理）	低（部署后稳定性高，维护简单）
扩展性	差（受限于单机性能）	中等（支持堆叠或集群）	高（芯片模块化设计，可横向扩展）
升级难度	易（软件更新）	中等（固件升级）	难（需更换硬件或重新流片）

8.2 防火墙的类型

软件、硬件、芯片级防火墙对比

5. 安全性对比

维度	软件防火墙	硬件防火墙	芯片级防火墙
抗攻击能力	低（依赖主机安全性，易被绕过）	高（独立OS，隔离性强）	极高（硬件隔离，无法被软件漏洞直接攻击）
功能完整性	基础（包过滤、状态检测）	全面（支持IPS、VPN、深度包检测）	定制化（专注特定协议加速，功能需预定义）
隐蔽性	低（易被扫描发现）	中等（独立IP，但可被探测）	高（集成于设备中，无独立IP）



8.2 防火墙的类型

软件、硬件、芯片级防火墙对比

如何选择？

- 个人/小型企业：软件防火墙（低成本） + 硬件防火墙（基础边界防护）。
- 中大型企业/数据中心：硬件防火墙（核心防护） + 芯片级防火墙（关键业务加速）。
- 电信/超大规模场景：芯片级防火墙（性能优先） + 软件定义策略（灵活控制）。

8.2 防火墙的类型

以防火墙的技术分类

按照防火墙的技术分类，分为包过滤型和应用代理型

1. 包过滤(Packet filtering)型

包过滤型防火墙工作在OSI网络参考模型的网络层和传输层，根据数据包头源地址、目的地址、端口号和协议类型等标志确定是否允许通过。只有满足过滤条件的数据包才被转发到相应的目的地，其余数据包则被从数据流中丢弃。其网络结构如图8-2所示。

包过滤方式是一种通用、廉价和有效的安全手段。通用，是因为它不是针对各个具体的网络服务采取特殊的处理方式，而是适用于所有网络服务；之所以廉价，是因为大多数路由器都提供数据包过滤功能，所以这类防火墙多数是由路由器集成的。有效，是因为它在很大程度上满足了绝大多数企业的安全要求。（防火墙与安全路由器的区别？）

8.2 防火墙的类型

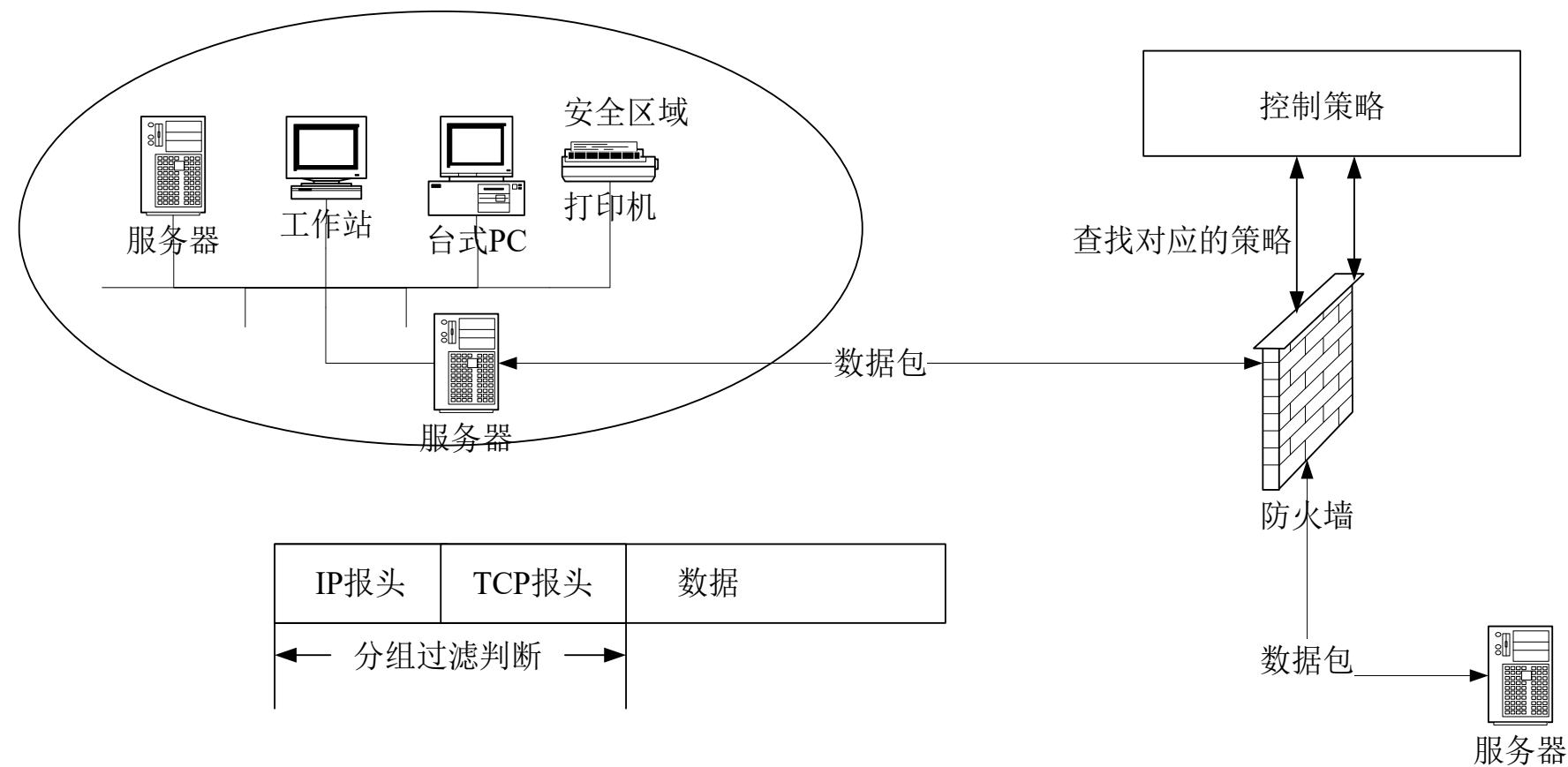


图8-2 包过滤防火墙的网络结构

8.2 防火墙的类型

整个防火墙技术发展过程中，**包过滤技术**出现了两种不同版本,称为“第一代静态包过滤”和“第二代动态包过滤”。

(1) 第一代静态包过滤类型防火墙

这类防火墙几乎是与路由器同时产生的，根据定义好的**过滤规则**审查每个**数据包**,以便确定其是否与某条**包过滤规则**匹配。**过滤规则基于数据包的报头信息**进行制订。报头信息中包括**IP**源地址、**IP**目标地址、**传输协议(TCP、UDP、ICMP等)**、**TCP/UDP**目标端口、**ICMP**消息类型等.其数据通路如图8-3。



图8-3 第一代静态包过滤防火墙的数据通路

8.2 防火墙的类型

(2) 第二代动态包过滤类型防火墙

这类防火墙采用**动态设置包过滤规则**的方法，避免了静态包过滤所具有的问题。这种技术后来发展成为**包状态监测 (Stateful Inspection)**技术。采用这种技术的防火墙对通过其建立的每一个连接都进行**跟踪**，并且根据需要可动态地在过滤规则中**增加或更新条目**，具体数据通路如图8-4。

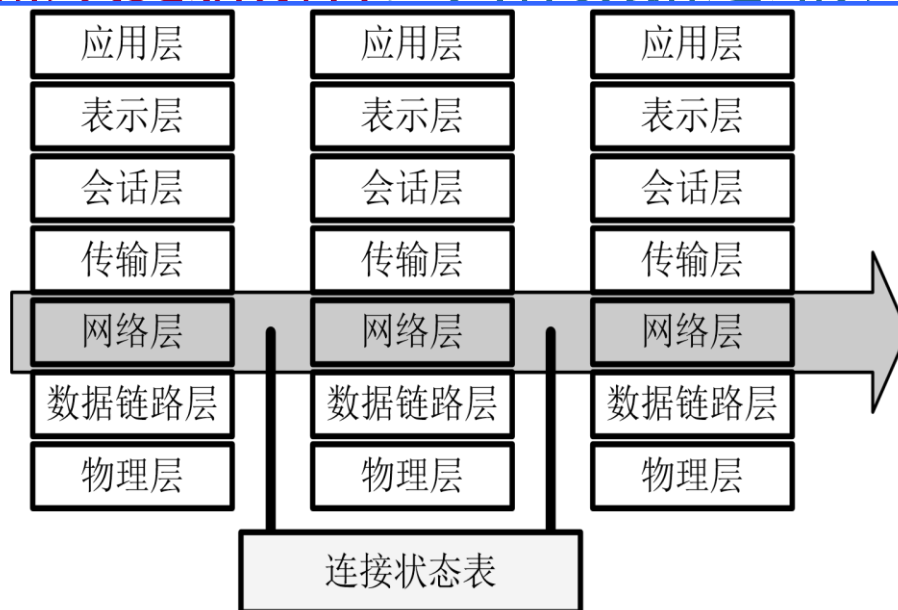


图8-4 第二代包过滤防火墙的数据通路

8.2 防火墙的类型

包过滤方式的优点是**不用改动客户机和主机上的应用程序**，因为它工作在**网络层和传输层**，与应用层无关。

但其弱点也是明显的：过滤判别的依据只是网络层和传输层的**有限信息**，因而各种安全要求不可能充分满足；在许多过滤器中，**过滤规则**的数目是有限制的，且随着规则数目的增加，性能也会受到很大影响；由于**缺少上下文关联信息**，不能有效地过滤如 **UDP**、**RPC**(远程过程调用)一类的协议；另外，大多数过滤器中**缺少审计和报警机制**，只能依据报头信息，而不能对用户身份进行验证，很容易受到“**地址欺骗型**”攻击。对安全管理人员素质要求高，建立安全规则时，必须对协议本身及其在不同应用程序中的作用有较深入的理解。过滤器通常和应用网关配合使用，共同组成防火墙系统。

8.2 防火墙的类型

2. 应用代理(Application Proxy)型

应用代理型防火墙是工作在OSI的最高层，即应用层。其**特点**是完全“阻隔”了网络通信流，通过对每种应用服务编制专门的代理程序，实现**监视和控制应用层通信流**的作用。其典型网络结构如图8-5所示。

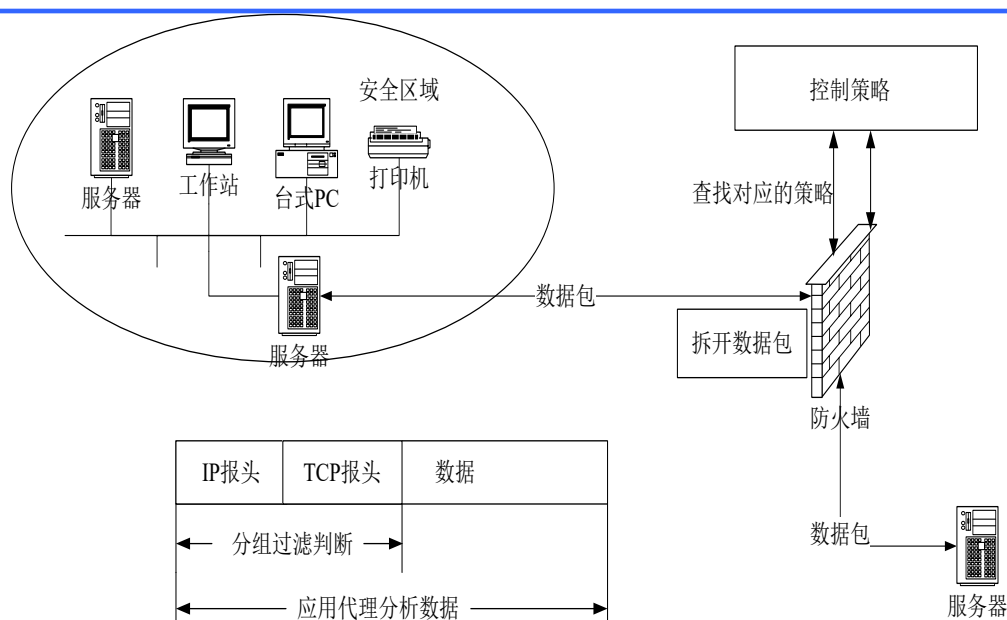


图8-5 应用代理型防火墙的网络结构

8.2 防火墙的类型

在代理型防火墙技术发展中，经历了两个不同的版本。

(1) 第一代应用网关(Application Gateway)型防火墙

这类防火墙是通过一种代理(Proxy)技术参与到一个TCP连接的全过程。如图8-6，从内部发出的数据包经过这样的防火墙处理后，就好像是源于防火墙外部网卡一样，从而达到**隐藏内部网结构**的作用。这种类型的防火墙被网络安全专家和媒体公认为是最安全的防火墙。**核心技术就是代理服务器技术。**

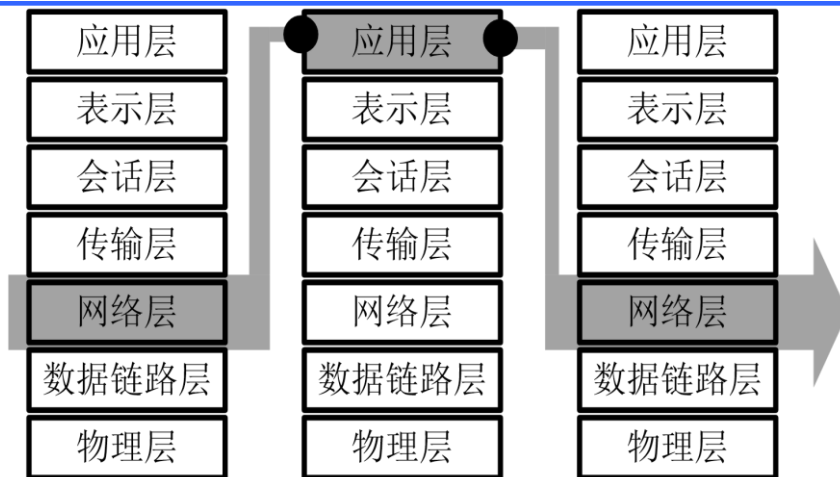


图8-6 第一代应用网关型防火墙数据通路

8.2 防火墙的类型

(2) 第二代自适应代理(Adaptive proxy)型防火墙

近几年才得到广泛应用的一种新防火墙类型。可以结合代理类型防火墙的安全性和包过滤防火墙的高速度等优点，在毫不损失安全性的基础之上将代理型防火墙的性能提高10倍以上。此类防火墙的数据通路如图8-7。组成这种类型防火墙的基本要素有两个：自适应代理服务器(Adaptive Proxy Server)与动态包过滤器(Dynamic Packet filter)。

策略A

条件							动作		选项
规则1	源区域 目标区域	源地址 目标地址	用户	应用	服务	时间段	动作	配置文件	启用记录日志
规则2	源区域 目标区域	源地址 目标地址	用户	应用	服务	时间段	动作	配置文件	启用记录日志
规则3	源区域 目标区域	源地址 目标地址	用户	应用	服务	时间段	动作	配置文件	启用记录日志
.....									



图8-7 第二代自适应代理型防火墙数据通路

8.2 防火墙的类型

(2) 第二代自适应代理(Adaptive proxy)型防火墙

在“自适应代理服务器”与“动态包过滤器”之间存在一个**控制通道**。在对防火墙进行配置时，用户仅仅将所需要的服务类型、安全级别等信息通过相应Proxy的管理界面进行设置就可以了。然后，自适应代理就可以根据用户的**配置信息**，决定是使用代理服务从应用层代理请求还是从网络层转发包。如果是后者，它将动态地通知包过滤器**增减过滤规则**，满足用户对**速度和安全性**的**双重要求**。

策略A

条件								动作		选项
规则1	源区域	源地址	用户	应用	服务	时间段	动作	配置文件		启用记录日志
	目标区域	目标地址								
规则2	源区域	源地址	用户	应用	服务	时间段	动作	配置文件		启用记录日志
	目标区域	目标地址								
规则3	源区域	源地址	用户	应用	服务	时间段	动作	配置文件		启用记录日志
	目标区域	目标地址								
.....										



图8-7 第二代自适应代理型防火墙数据通路



8.2 防火墙的类型

代理型防火墙最突出的**优点**就是安全。由于其工作于**最高层**，所以可以对网络中任何一层数据通信进行**筛选保护**，而不是像包过滤那样，只对网络层的数据过滤。另外，代理型防火墙采取的是一种**代理机制**，它可以为每一种应用服务建立一个专门的代理，所以内、外部网络之间的通信不是直接的，而是都需要先经过代理服务器审核，通过后再由代理服务器代为连接，根本没有给内、外部网络计算机任何直接会话的机会，从而**避免**了入侵者使用数据驱动类型的攻击方式入侵内部网。

代理型防火墙的最大**缺点**就是速度相对比较慢，当用户对内、外部网络网关的吞吐量要求比较高时，代理型防火墙就会成为内、外部网络之间的瓶颈。因为防火墙需要为不同的网络服务建立专门的代理服务，在自己的代理程序中为内、外部网络用户建立连接时需要时间，所以给系统性能带来了一些负面影响，但通常不会很明显。

8.2 防火墙的类型

包过滤型、应用代理型防火墙对比

防火墙类型	包过滤型防火墙	应用代理型防火墙
工作原理	网络层和传输层，数据过滤	应用层，数据转发
安全性	低	高
性能	好	差
配置管理	简单	复杂
应用场景	对网络速度要求高、流量较大的网络边界防护，如企业网络与互联网之间的边界	对安全性要求较高的网络环境，如政府部门、金融机构等



8.2.2 防火墙的类型

8.2.3 以防火墙体系结构分类

主要有：单一主机防火墙、路由器集成式防火墙和分布式防火墙三种。

(1) **单一主机防火墙**是最为**传统**的防火墙，独立于其它网络设备，它**位于**网络边界。与**PC**结构差不多，区别是一般集成两个以上的以太网卡，连接一个以上的内、外部网络。其中的硬盘用来存储防火墙所用的基本程序和日志。它具备非常高的稳定性、实用性和非常高的系统吞吐性能。

(2) **路由器集成式防火墙**是将防火墙功能集成在中、高档路由器中，大大降低了网络设备购买成本。

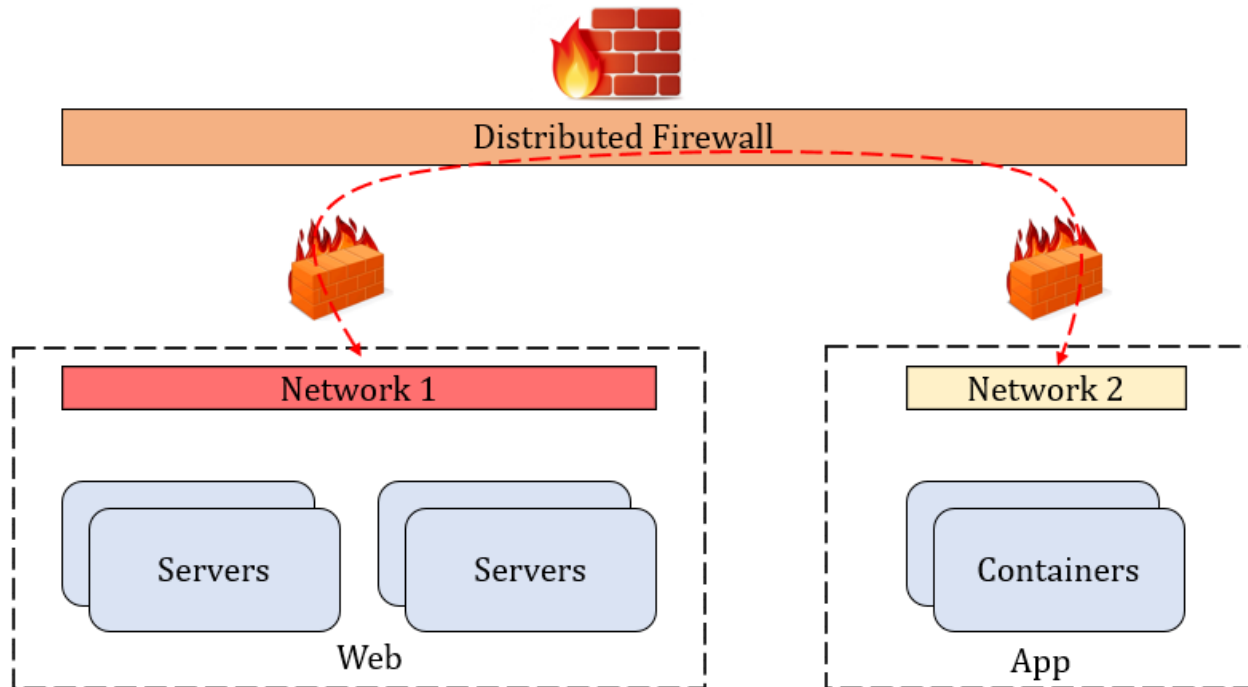
8.2.2 防火墙的类型

8.2.3 以防火墙体系结构分类

(3) **分布式防火墙**不是只是位于网络边界，不再是一个独立的硬件实体，而是由**多个软、硬件**组成的系统，**渗透于**网络的每一台主机，对整个内部网络的主机实施保护。

在网络服务器中，通常会安装一个防火墙系统用于管理软件，在服务器及各主机上安装有集成网卡功能的**PCI防火墙卡**，这样一块防火墙卡同时兼有**网卡和防火墙**的双重功能，只需要一个防火墙系统就可以彻底保护内部网络。各主机把任何其他主机发送的通信连接都视为“不可信”的，都需要严格过滤。

8.2.2 防火墙的类型



8.2.2 防火墙的类型

8.2.4 防火墙在性能等级上的分类

如果按防火墙的性能来分可以分为百兆级防火墙和千兆级防火墙两类。

因为防火墙通常位于网络边界，所以不可能只是十兆级的。这主要是指防火墙的通道带宽(Bandwidth)，或吞吐率。当然通道带宽越宽，性能越高，这样的防火墙因包过滤或应用代理所产生的延时也越小，对整个网络通信性能的影响也就越小。



8.2.2 防火墙的类型

讨论思考：

- (1) 软件防火墙、硬件防火墙和芯片防火墙的主要区别是什么？
- (2) 包过滤防火墙工作在OSI模型的哪一层？
- (3) 应用代理防火墙为什么比包过滤防火墙的性能要好？
- (4) 什么是DMZ？有什么作用？

8.3 防火墙的主要应用

1 企业网络体系结构

来自外部用户和内部用户的网络入侵日益频繁，必须建立保护网络不会受到这些入侵破坏的机制。虽然防火墙可以为网络提供保护，但是它同时也会耗费资金，并且会对通信产生障碍，因此应该尽可能寻找**最经济、最高效**的防火墙。

企业网络体系结构如图8-8，由三个区域组成：

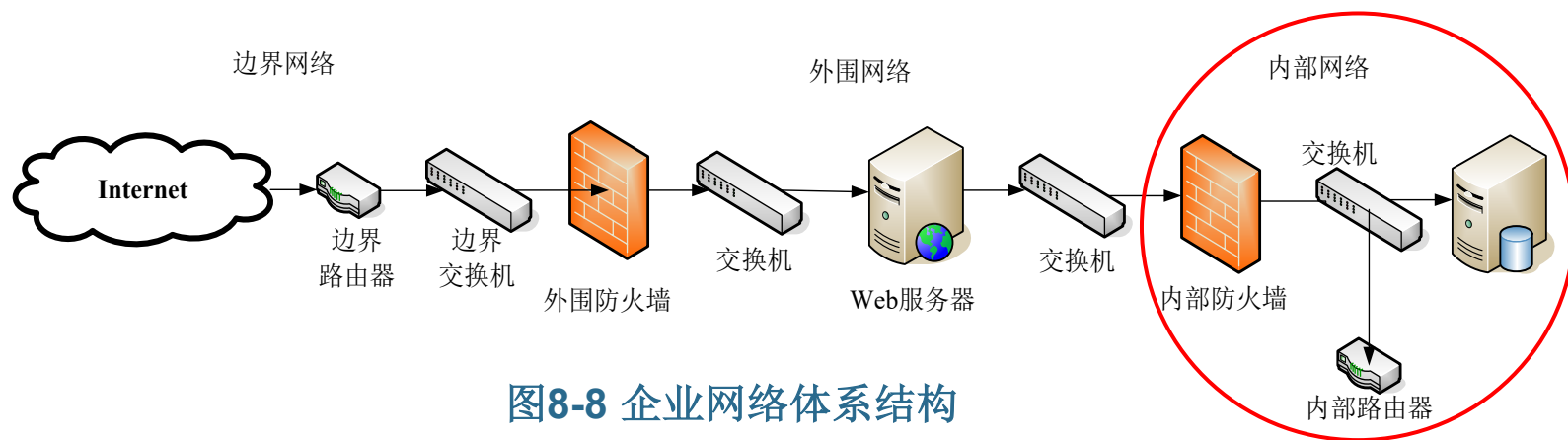


图8-8 企业网络体系结构

8.3 防火墙的主要应用

1 企业网络体系结构

①**边界网络**：此网络通过路由器直接面向 **Internet**，应该以基本网络通信**筛选**的形式提供初始层面的保护。路由器通过外围防火墙将数据一直提供到外围网络。

②**外围网络**：此网络通常称为 **DMZ**（demilitarized zone network，**无戒备区网络**）或**边缘网络**，它将外来用户与 **Web** 服务器或其他服务链接起来。然后，**Web** 服务器将通过内部防火墙链接到内部网络。

③**内部网络**：内部网络则链接各个内部服务器（如 **SQL Server**）和内部用户。

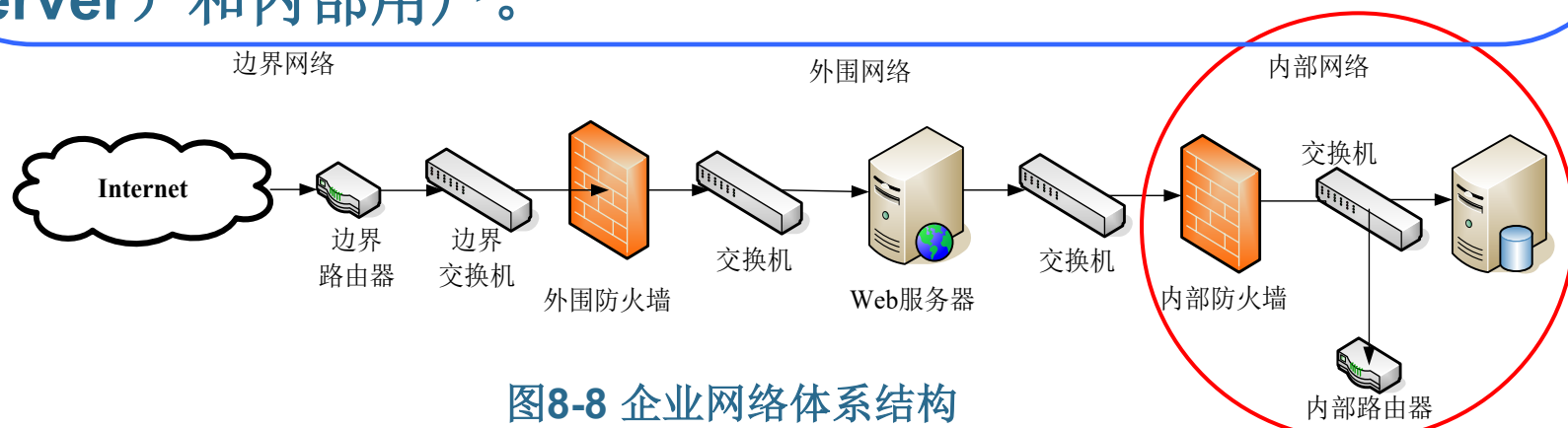


图8-8 企业网络体系结构

8.3 防火墙的主要应用

以天网防火墙为例，组建的小型企业网络方案如图8-9所示。

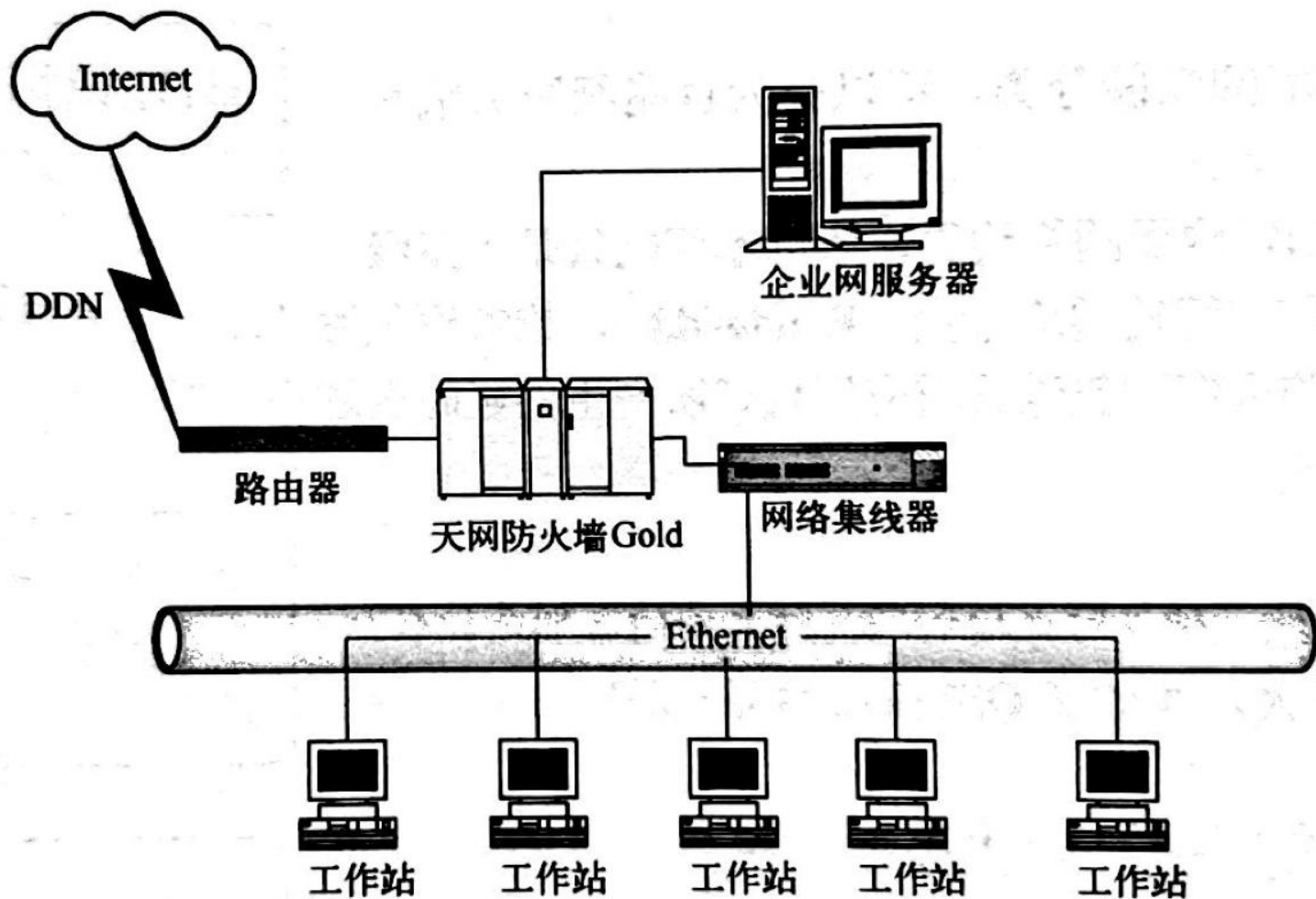


图8-9 使用天网防火墙典型企业结构

8.3 防火墙的主要应用

2 内部防火墙系统应用

内部防火墙用于控制对内网访问和从内网访问。**用户类型：**

1) **完全信任用户**：机构成员到外围区域或 **Internet** 的内部用户、外部用户(如分支办事处工作人员)、远程用户或在家中办公的用户。

2) **部分信任用户**：例如组织的业务合作伙伴，这类用户的信任级别比不受信任的用户高。但是，其信任级别经常比组织的雇员要低。

3) **不信任用户**：例如组织公共网站的用户。理论上，来自 **Internet** 的不受信任的用户应该仅访问外围区域中的 **Web** 服务器。如果他们需要对内部服务器进行访问，受信任的 **web** 服务器会代表他们进行查询，这样永远不允许不受信任的用户通过此内部防火墙。

8.3 防火墙的主要应用

2 内部防火墙系统应用

在选择使用的防火墙类别时，应该考虑许多问题。表 8-1 着重说明了这些问题。

表 8-1 内部防火墙类别选择问题

问题	以此容量实现的防火墙的典型特征
所需的防火墙 功能 ，如 安全 管理员所指定的	这是所需的安全程度与功能的成本以及增加的安全可能导致的性能的潜在下降之间的权衡。虽然许多组织希望这一容量的防火墙提供最高的安全性，但是有些组织并不愿意接受伴随而来的性能降低。例如，对于容量非常大的非电子商务网站，基于通过使用静态数据包筛选器而不是应用程序层筛选获得的较高级别的吞吐量，可能允许较低级别的安全。
无论是专用 物理 设备，提供其他功能，还是物理设备上的 逻辑 防火墙	这取决于所需的性能、数据的敏感性和需要从外围区域进行访问的频率。
设备的 管理功能 要求如组织的管理体系结构所指定的。	通常使用某种形式的日志，但是通常还需要事件监视机制。您可能在这里选择不允许远程管理以阻止恶意用户远程管理设备。
吞吐量 要求很可能由组织内的网络和服务管理员来确定。	这些将根据每个环境而变化，但是设备或服务器中硬件的功能以及要使用的防火墙功能将确定整个网络的可用吞吐量。
可用性 要求	也要取决于来自 Web 服务器的访问要求。如果它们主要用于处理提供网页的信息请求，则内部网络的通信量将很低。但是，电子商务环境将需要高级别的可用性



8.3 防火墙的主要应用

(1).内部防火墙规则

内部防火墙监视外围区域和信任的内部区域之间的通信。由于这些网络之间**通信类型和流的复杂性**，内部防火墙的技术要求比外围防火墙的**技术要求更加复杂**。

通常，内部防火墙在默认情况下或通过设置将需要实现下列规则：

1)默认情况下，阻止所有数据包。

2)在外围接口上，阻止看起来好像来自内部地址的传入数据包，以阻止欺骗。在**内部接口上**，阻止看起来好像来自外部地址的传出数据包，以限制内部攻击。

8.3 防火墙的主要应用

(1).内部防火墙规则

3)允许从内部 **DNS 服务器**到 **DNS 解析程序堡垒主机**的基于 **UDP** 的查询和响应。允许从 **DNS 解析程序堡垒主机**到内部 **DNS 服务器**的基于 **UDP** 的查询和响应。允许从内部 **DNS服务器**到 **DNS 解析程序堡垒主机**的基于 **TCP** 的查询，包括对这些查询的响应。允许从 **DNS解析程序堡垒主机**到内部 **DNS 服务器**的基于 **TCP** 的查询，包括对这些查询的响应。

4)允许来自 **VPN 服务器**上后端的通信到达内部主机，并且允许响应返回到 **VPN服务器**。允许验证通信到达内部网络上的**RADIUS 服务器**，并且允许响应返回到 **VPN服务器**。



8.3 防火墙的主要应用

堡垒（Bastion）主机，堡垒主机是位于外围网络中的服务器，向内部和外部用户提供服务。堡垒主机**包括 Web 服务器和 VPN 服务器**。

8.3 防火墙的主要应用

(2).内部防火墙的可用性

为了增加防火墙的可用性，可以将它实现为具有或不具有冗余组件的单一防火墙设备，或合并了某些类型的故障转移和/或负载平衡机制的防火墙的冗余对。

为某些很可能发生故障的组件（如电源）配置备用系统，可改进防火墙的适应性，因为如果第一个组件发生故障，不会对运营造成任何影响。



8.3 防火墙的主要应用

(1) 没有冗余组件的单一防火墙

优点：1)**成本低**。由于只有一个防火墙，所以硬件成本和许可成本都较低。2)**管理简单**。管理工作得到简化，因为整个站点或企业只有一个防火墙。3)**单个记录源**。所有通信记录操作都集中在一台设备上。

缺点：1)**单一故障点**。对于入站和/或出站访问存在单一故障点。2)**通信瓶颈**。单一防火墙可能是一个通信瓶颈，这取决于连接的个数和所需的吞吐量。

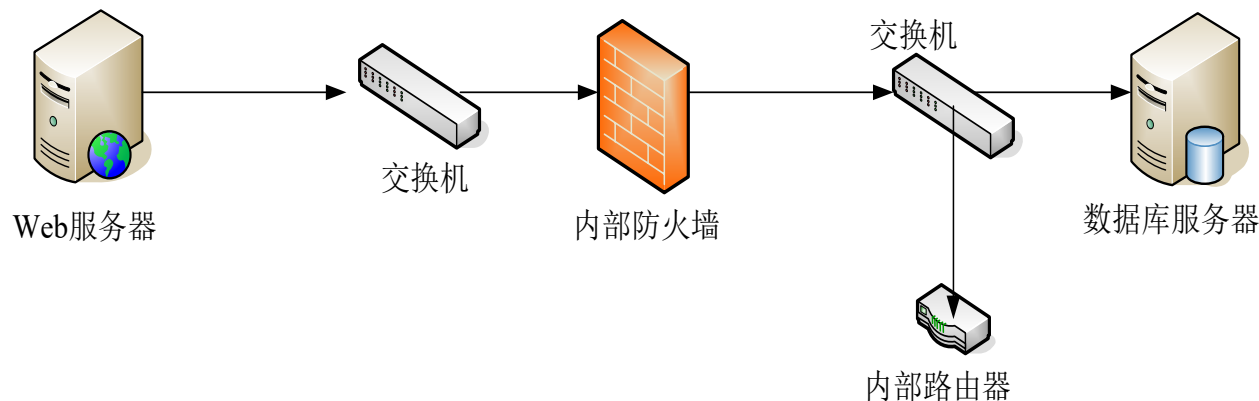


图8-10没有冗余组件的单一防火墙

8.3 防火墙的主要应用

(2) 具有冗余组件的单一防火墙

优点：1) **成本低**。由于只有一个防火墙，所以硬件成本和许可成本都较低。冗余组件(如电源)的成本也不高。2) **管理简单**。管理工作简化，整个站点或企业只有一个防火墙。3) **单个记录源**。所有通信记录操作都集中在一台设备上。

缺点：1) **单一故障点**。根据冗余组件的数量不同，入站和/或出站访问仍然可能只有一个故障点。2) **成本**。成本比没有冗余防火墙高，且可能还需要更高类别的防火墙才可以添加冗余。3) **通信瓶颈**。单一防火墙可能是一个通信瓶颈，这取决于连接的个数和所需的吞吐量。

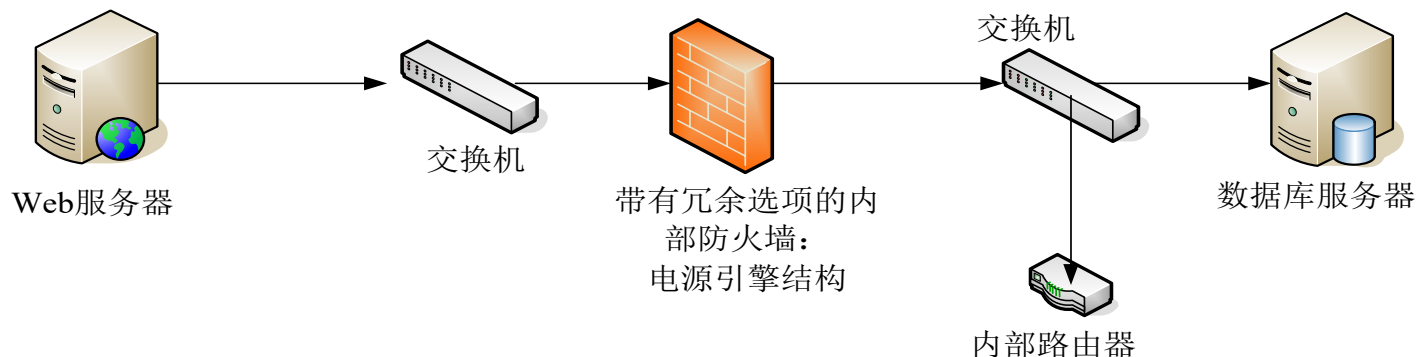


图8-11 具有冗余组件的单一防火墙

8.3 防火墙的主要应用

(3) 容错防火墙

优点：1)容错。用成对服务器或设备有助于提供所需级别的容错能力。2)集中通信日志。由于两个防火墙或者其中的一个可能正在记录其他合作者或某个单独服务器的活动，所以通信日志变得更可靠。3)可能的状态共享。根据产品的不同，本级别中的防火墙之间可能可以共享会话的状态。

缺点：1)复杂程度增加。由于网络通信的多路径性质，此类解决方案的设置和支持更复杂。2)配置更复杂。各组防火墙规则如果配置不正确，可能会导致安全漏洞以及支持问题。3)成本增加。至少需要两个防火墙时，成本将超过单一防火墙。

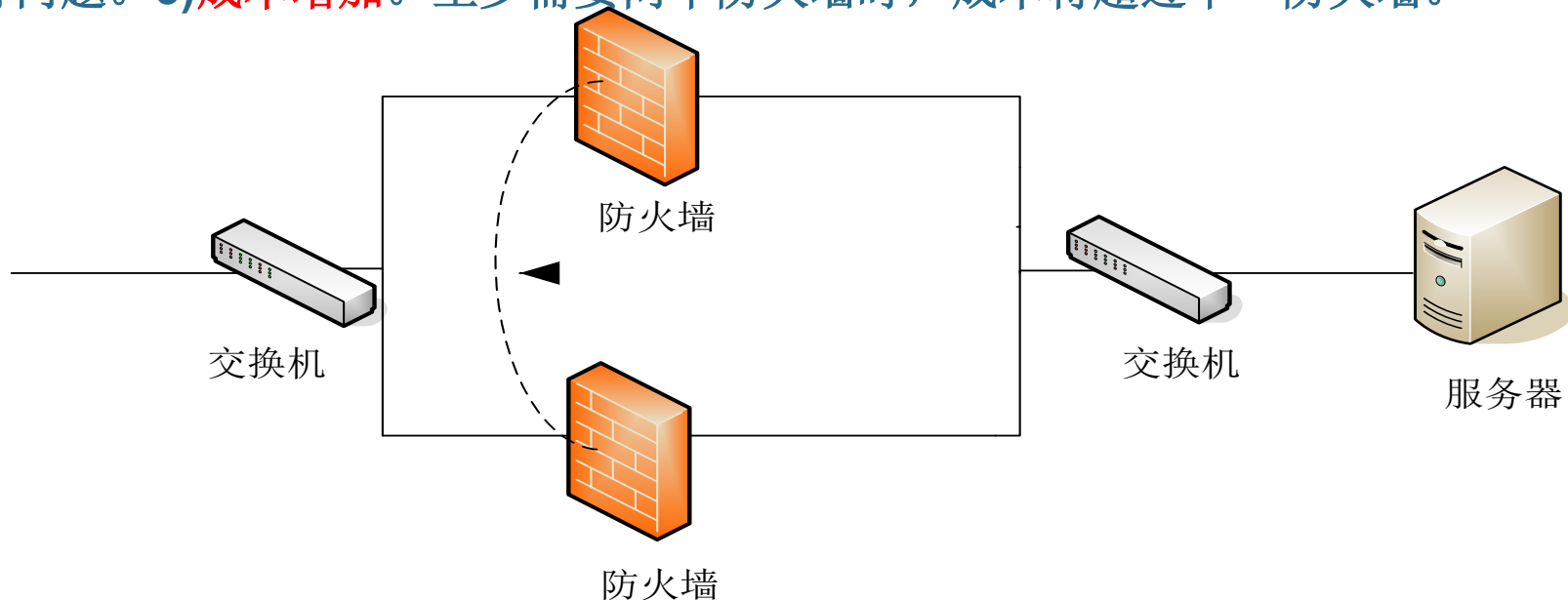


图8-12 容错防火墙

8.3 防火墙的主要应用

3 外围防火墙系统设计

设置外围防火墙是为了满足组织边界之外用户的需要。这些用户类型包括：

完全信任用户：如机构各个分支办事处的工作人员、远程用户或者在家工作的用户。

部分信任用户：机构的业务合作伙伴，其用户的信任级别比不信任的用户高。但是，这类用户通常又比组织的员工低一个信任级别。

不信任用户：例如组织公共网站的用户。

注意外围防火墙特别容易受到外部攻击，因为入侵者必须破坏该防火墙才能进一步进入内部网络。因此，它将成为明显的攻击目标。

8.3 防火墙的主要应用

3 外围防火墙系统设计

边界位置中使用的防火墙是通向外部世界的通道。在很多大型组织中，此处实现的防火墙类别通常是高端硬件防火墙或者服务器防火墙，但是某些组织使用的是路由器防火墙。选择防火墙类别用作外围防火墙时，应该考虑一些问题。

表8-2 外围防火墙类别选择问题

问题	在此位置实现的典型防火墙特征
安全管理员指定的必需防火墙功能	这是一个必需安全性级别与功能成本以及增加安全性可能导致的性能下降之间的平衡问题。虽然很多组织想通过外围防火墙得到最高的安全性，但有些组织不想影响性能。例如，不涉及电子商务的高容量网站，在通过使用静态数据包筛选器而不是使用应用程序层筛选而获取较高级别吞吐量的基础上，可能允许较低级别的安全性。
该设备是一个专门的物理设备、提供其他功能，还是物理设备上的一个逻辑防火墙	作为 Internet 和企业网络之间的通道，外围防火墙通常实现为专用的设备，这样是为了在该设备被侵入时将攻击的范围和内部网络的可访问性降到最低。
组织的管理体系结构决定了设备的可管理性要求	通常，需要使用某些形式的记录，一般还同时需要一种事件监视机制。为了防止恶意用户远程管理该设备，此处可能不允许远程管理，而只允许本地管理。
吞吐量要求可能是由组织内部的网络和服务管理员决定的	这些要求会根据每个环境的不同而发生变化，但是设备或者服务器中的硬件处理能力以及所使用的防火墙功能将决定可用的网络整体吞吐量。
可用性要求	作为大型组织通往 Internet 的通道，通常需要高级的可用性，尤其是当外围防火墙用于保护一个产生营业收入的网站时。



8.3 防火墙的主要应用

1. 外围防火墙规则

外围防火墙需要以默认的形式或通过配置实现下列规则：

- 1) 拒绝所有通信，除非显式允许的通信。
- 2) 阻止声明具有内部或者外围网络源地址的外来数据包。
阻止声明具有外部源 IP 地址的外出数据包(通信应该只源自堡垒主机)。
- 3) 允许从 DNS 解析程序到 Internet 上的 DNS 服务器的基于 UDP 的 DNS 查询和应答。允许从 Internet DNS 服务器到 DNS 解析程序的基于 UDP 的 DNS 查询和应答。
- 4) 允许基于 UDP 的外部客户端查询 DNS 解析程序并提供应答。允许从 Internet DNS 服务器到 DNS 解析程序的基于 TCP 的 DNS 查询和应答。允许从出站 SMTP 堡垒主机到 Internet 的外出邮件。

8.3 防火墙的主要应用

2. 外围防火墙可用性

(1) 单个无冗余组件的防火墙

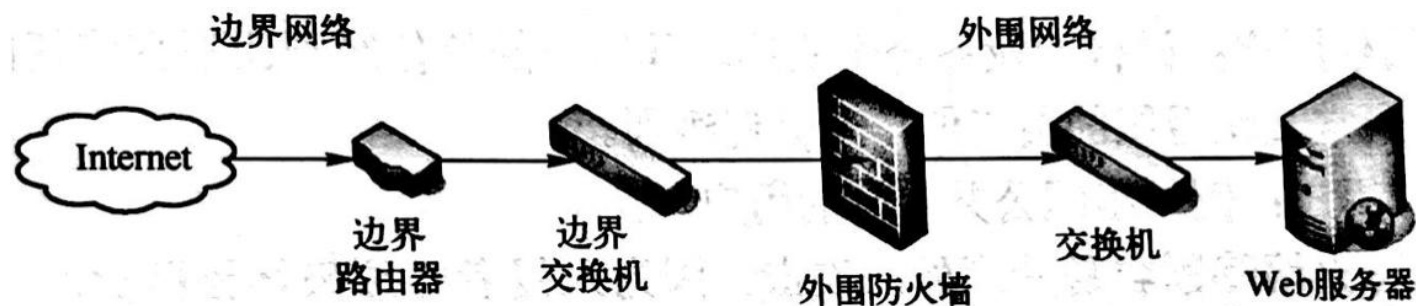


图8-13 单个无冗余组件的防火墙

(2) 单个带冗余组件的防火墙

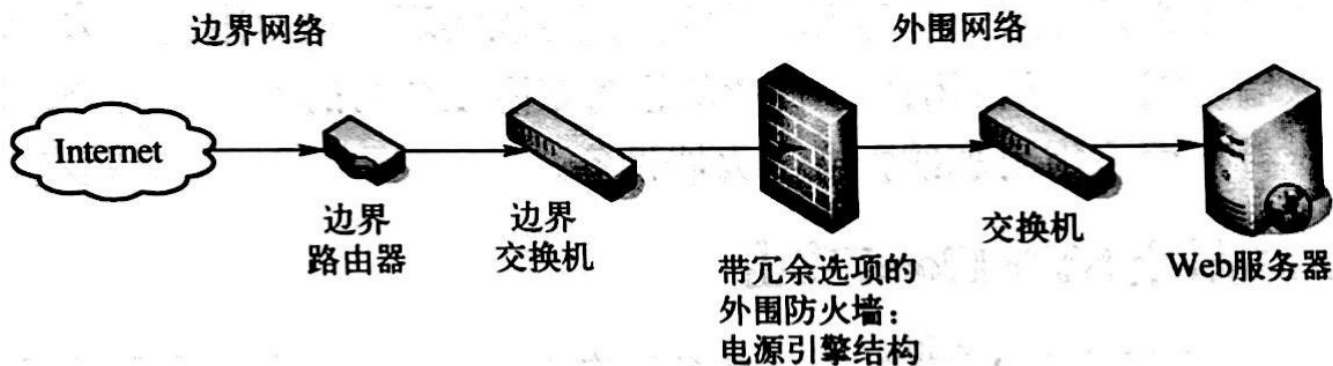


图8-14 单个带冗余组件的防火墙

8.3 防火墙的主要应用

(3) 容错防火墙

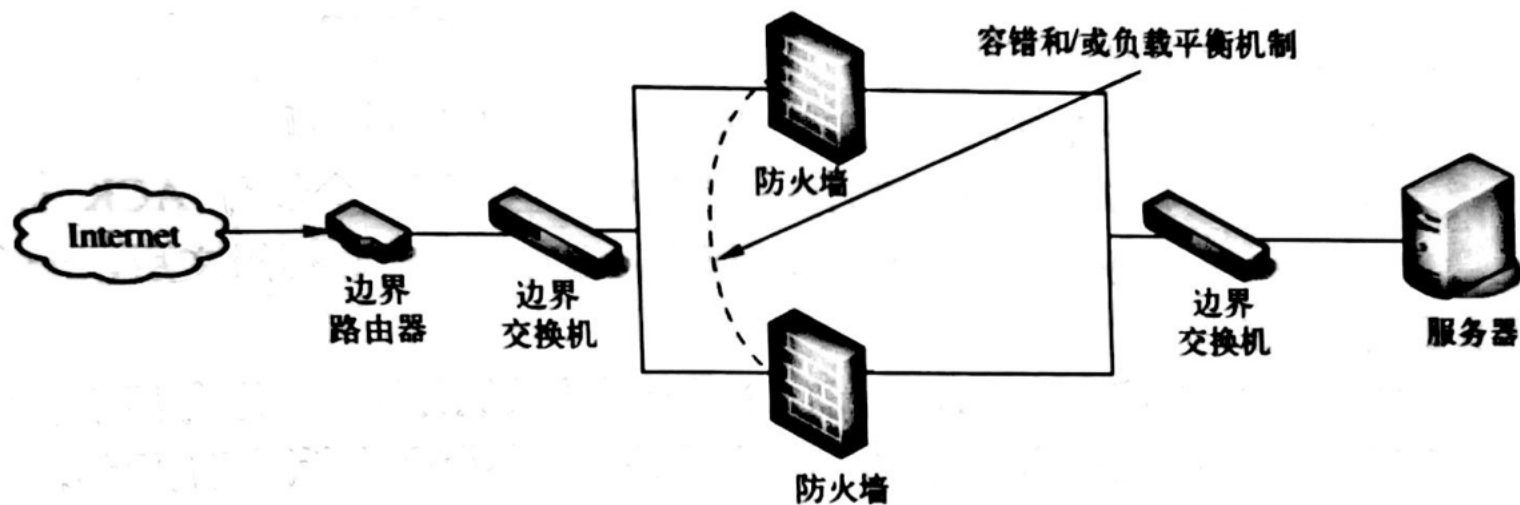
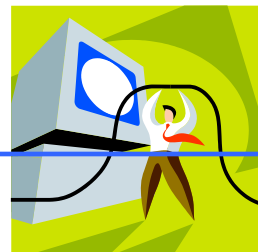


图8-15 容错防火墙

8.3.4 用防火墙阻止SYN Flood攻击

1. SYN Flood攻击原理

SYN Flood攻击所利用的是**TCP**协议存在的漏洞。**TCP**协议是面向连接的，在每次发送数据以前，都会在服务器与客户端之间先虚拟出一条路线，称**TCP连接**，以后的各数据通信都经由该路线进行，直到本次**TCP**连接结束。而**UDP**协议则是无连接的协议，基于**UDP**协议的通信，各数据报并不经由相同的路线。在整个**TCP**连接中需要经过三次协商，俗称“**三次握手**”来完成。

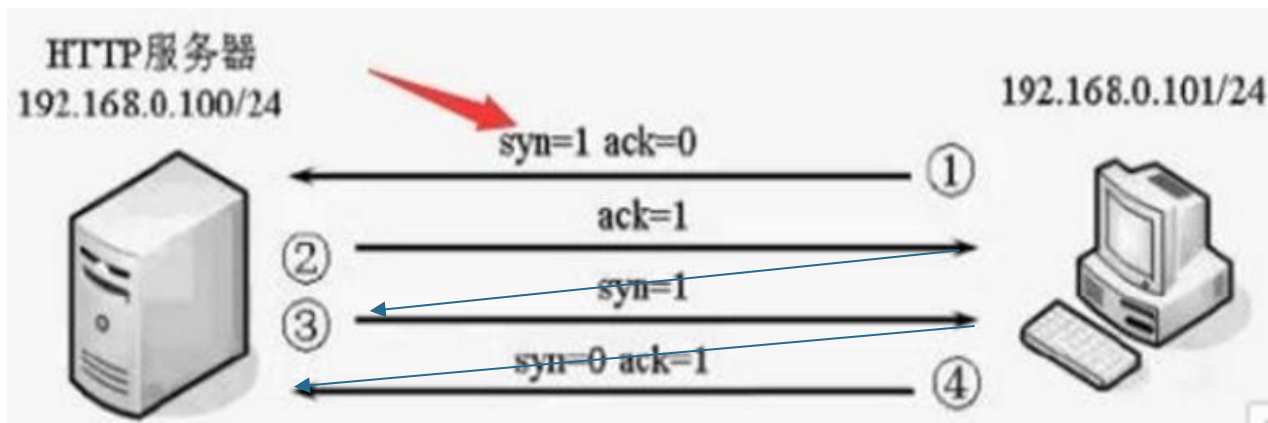


8.3.4 用防火墙阻止SYN Flood攻击

第一次：客户端发送一个带有**SYN**标记的**TCP**报文到服务端,正式开始**TCP**连接请求。在发送的报文中指定了自己所用的端口号以及**TCP**连接初始序号等信息。

第二次：服务器端在接收到来自客户端的请求之后,返回一个带有**SYN+ACK**标记的报文，表示接受连接,并将**TCP**序号加1。

第三次：客户端接收到来自服务器端的确认信息后,也返回一个带有**ACK**标记的报文,表示已接收到来自服务器端的确认信息.服务器端在得到该数据报文后,一个**TCP**连接才算真正建立起来。



8.3.4 用防火墙阻止SYN Flood攻击

在以上三次握手中，当客户端发送一个**TCP**连接请求给服务器端，服务器也发出了相应的响应数据报文之后，可能由于某些原因（如客户端突然死机或断网等原因），客户端不能接收到来自服务器端的确认数据报，这就造成了以上三次连接中的第一次和第二次握手的**TCP半连接**。

由于服务器端发出了带**SYN+ACK**标记的报文，却并没有得到客户端返回相应的**ACK**报文，于是服务器就进入等待状态，并定期反复进行**SYN+ACK**报文重发，直到客户端确认收到为止。

这样服务器端就会一直处于等待状态，使得**CPU**及其他资源严重消耗，不仅服务器可能崩溃，而且网络也可能处于瘫痪。



8.3.4 用防火墙阻止SYN Flood攻击

SYN Flood攻击正是利用了**TCP**连接的这样一个漏洞来实现攻击目的的。

当恶意的客户端构造出大量的这种**TCP**半连接发送到服务器端时，服务器端就会一直**陷入等待的过程中**，并耗用大量的**CPU**资源和内存资源来进行**SYN+ ACK**报文的重发，最终使得服务器端崩溃。

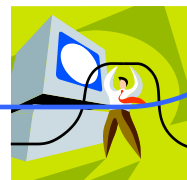


8.3.4 用防火墙阻止SYN Flood攻击

2. 用防火墙防御SYN Flood攻击

(1) 两种主要类型防火墙（包过滤型和应用代理型防火墙）的防御原理

应用代理型防火墙的防御方法是客户端要与服务器建立TCP连接的三次握手过程中，充当**代理角色**，这样客户端要与服务器端建立一个TCP连接，就必须先与防火墙进行三次TCP握手，当客户端和防火墙三次握手成功之后，再由防火墙与客户端进行三次TCP握手，完成后再进行一个TCP连接的三次握手。防火墙相当于起到一种隔离保护作用，安全性较高。当外界对内部网络中的服务器端进行SYN Flood攻击时，实际上遭受攻击的不是服务器而是防火墙。而防火墙自身则又是具有抗攻击能力的，可以通过规则设置，拒绝外界客户端不断发送的SYN+ACK报文。如图8-16所示。



8.3.4 用防火墙阻止SYN Flood攻击

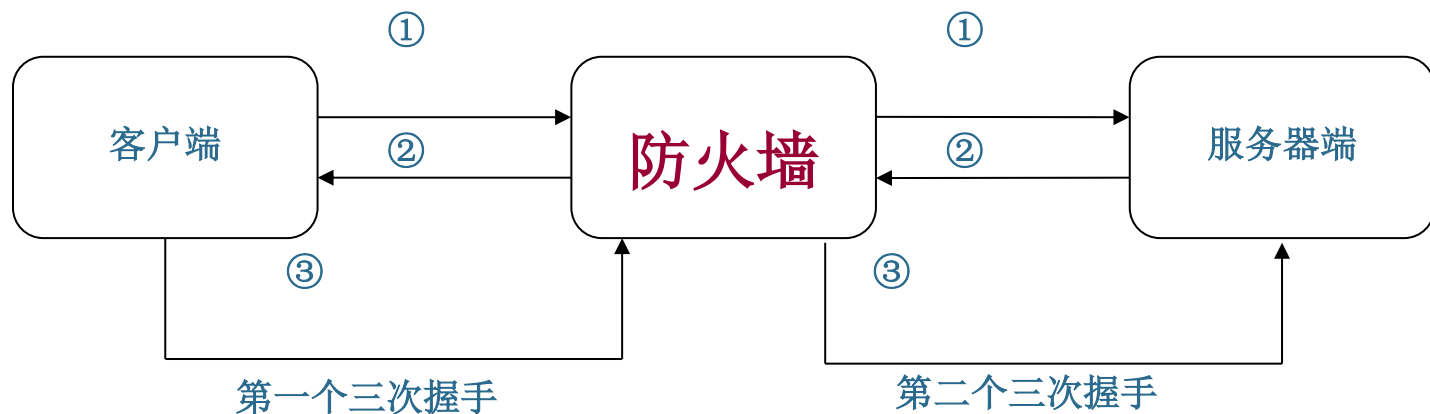


图8-16 两个三次握手过程

从整个过程可以看出，由于所有的报文都是通过防火墙转发，而且未同防火墙建立起TCP连接就无法同服务器端建立连接，所以使用这种防火墙就相当于起到一种隔离保护作用，安全性较高。当外界对内部网络中的服务器端进行SYN Flood攻击时，实际上遭受攻击的不是服务器而是防火墙。而防火墙自身则又是具有抗攻击能力的，可以通过规则设置，拒绝外界客户端不断发送的SYN+ACK报文。

8.3.4 用防火墙阻止SYN Flood攻击

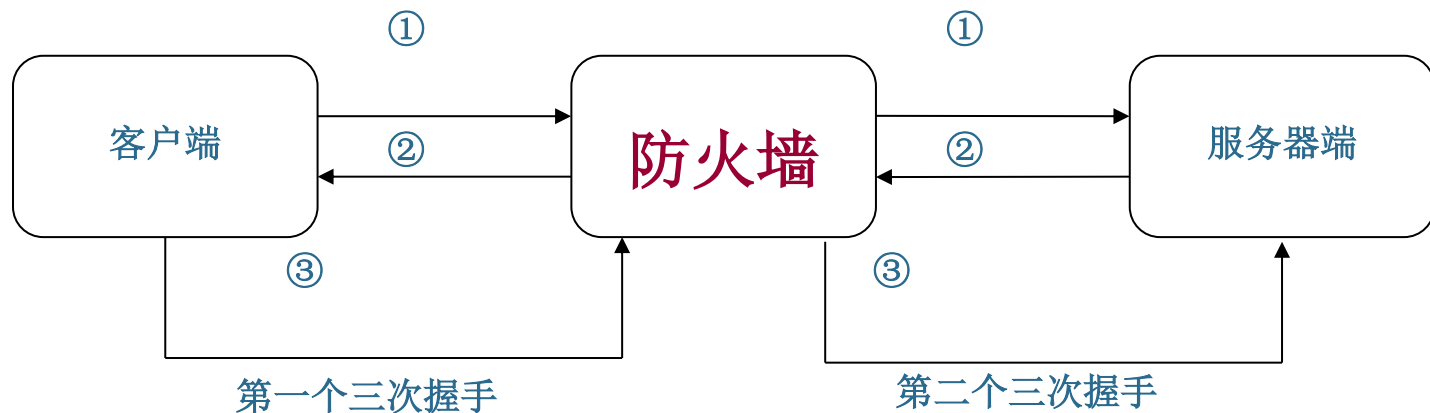


图8-16 两个三次握手过程

但是采用这种防火墙有一个很大的缺点，那就是客户端和服务端建立一个 **TCP** 连接时，防火墙就进行了**六次握手**，可见防火墙的工作量是非常大的。因此采用这种防火墙时，要求该防火墙要有**较大的处理能力以及内存**。代理应用型防火墙通常**不适合访问流量大的服务器或者网络**。

8.3.4 用防火墙阻止SYN Flood攻击

包过滤型防火墙是工作于IP层或之下，对外来的数据报文，只是起一个**过滤的作用**。当数据包合法时，它就直接将其转发给服务器，起到的是**转发作用**。

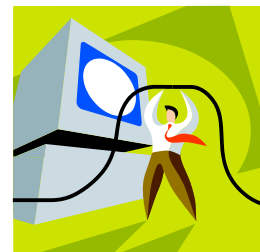
在包过滤型防火墙中，客户端同服务器的三次握手直接进行，并不需要通过防火墙来代理进行。包过滤型防火墙**效率要较网关型防火墙高**，**允许数据流量大**。但是这种防火墙如果配置不当的话，会让攻击者绕过防火墙而直接攻击到服务器。而且允许数据量大会有利于**SYN Flood攻击**。这种防火墙**适合于大流量**的服务器，但是需要设置妥当才能保证服务器具有较高的安全性和稳定性。



8.3.4 用防火墙阻止SYN Flood攻击

(2) 防御SYN Flood攻击的防火墙设置

除了可以直接采用以上两种不同类型的防火墙进行SYN Flood防御外，还可进行一些特殊的防火墙设置来达到目的。针对SYN Flood攻击，防火墙通常有**三种防护方式**：**SYN网关**、**被动式SYN网关**和**SYN中继**。



8.3.4 用防火墙阻止SYN Flood攻击

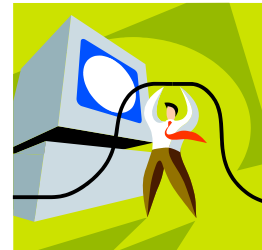
1)**SYN 网关**:在这种方式中，防火墙收到客户端的**SYN**包时，直接转发给服务器;防火墙收到服务器的**SYN/ACK**包后，一方面将**SYN/ACK**包转发给客户端，另一方面以客户端的名义给服务器回送一个**ACK**包，完成一个完整的**TCP**三次握手，让服务器端由半连接状态进入连接状态。当客户端真正的**ACK**包到达时，有数据则转发给服务器，否则丢弃该包。由于服务器在连接状态要比在半连接状态能承受得更多，所以这种方法能有效减轻对服务器的攻击。

8.3.4 用防火墙阻止SYN Flood攻击

2) **被动式 SYN 网关**: 在这种方式中，设置防火墙的 **SYN** 请求超时参数，让它远小于服务器的超时期限。防火墙负责转发客户端发往服务器的 **SYN** 包，包括服务器发往客户端的 **SYN/ACK** 包和客户端发往服务器的 **ACK** 包。这样，如果客户端在防火墙计时器到期时还没发送 **ACK** 包，防火墙将向服务器发送 **RST** 包，以使服务器从队列中删去该半连接。由于防火墙的超时参数远小于服务器的超时期限，因此这样也能有效防止 **SYNFlood** 攻击。

8.3.4 用防火墙阻止SYN Flood攻击

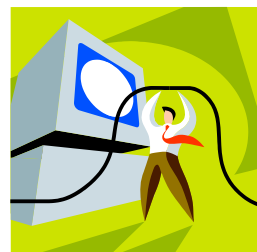
3)**SYN 中继**:在这种方式中，防火墙在收到客户端的 **SYN** 包后，并不向服务器转发而是记录该状态信息，然后主动给客户端回送 **SYN/ACK** 包。如果收到客户端的 **ACK**包，表明是正常访问，由防火墙向服务器发送 **SYN** 包并完成三次握手。这样由防火墙作为代理实现客户端和服务端连接，可以完全过滤不可用连接发往服务器。



8.3 防火墙的主要应用

📖讨论思考:

- (1) 为什么将企业网络划分为3个区域? 外围网络有什么用处?
- (2) 冗余容错技术主要有哪些? 增加冗余后为什么安全性会有所提高?
- (3) SYN Flood攻击是利用了什么漏洞?
- (4) DDoS是如何实现的? 常用的攻击手段除了SYN Flood以外还有哪些?



关于防火墙，以下说明错误的是()。

- ☐ A 防火墙能隐藏内部IP地址
- ☐ B 防火墙能控制进出内网的信息流向和信息包
- ☐ C 防火墙能提供VPN功能
- ☒ D 防火墙能组织来自内部的威胁

提

交

以下说法正确的是()。

- ☐ A 防火墙能抵御一切网络攻击
- ☐ B 防火墙是一种主动安全策略执行设备
- ☐ C 防火墙本身不需要提供保护
- ☒ D 防火墙如果配置不当，会导致更大的安全风险

提

交



8.4 本章小结

本章简要介绍了防火墙的相关知识，通过深入了解防火墙的分类以及各种防火墙类型的优缺点，有助于更好地分析配置各种防火墙策略。阐述了企业防火墙的体系结构及配置策略，同时通过对 SYN Flood 攻击方式的分析，给出了解决此类攻击的一般性原理。



课后作业

练习与实践8

1 (4) (5)

2

3 (2)

作业提交：手写拍照或电子文档，保存为pdf格式，命名“学号-姓名”
班长/学委打包发我QQ（97251651）或者邮箱（jingkun@ahu.edu.cn）

8.4 实验8 国产亨通工业控制防火墙应用

亨通工业控制防火墙主要提供的功能，包括：基于状态检测的访问控制、工业协议解析处理、系统智能建模、透明接入技术、入侵检测过滤和方便高效的管理和维护。

根据不同网络层次、区域、工艺对安全防护的等级要求不同情况下，工控结合现场环境提出有针对性的防护方式，包括：网络防护，层次防护，区域防护，重点设备保护。

8.4 实验8 国产亨通工业控制防火墙应用

工控防火墙的典型组网及应用，如图8-18所示。

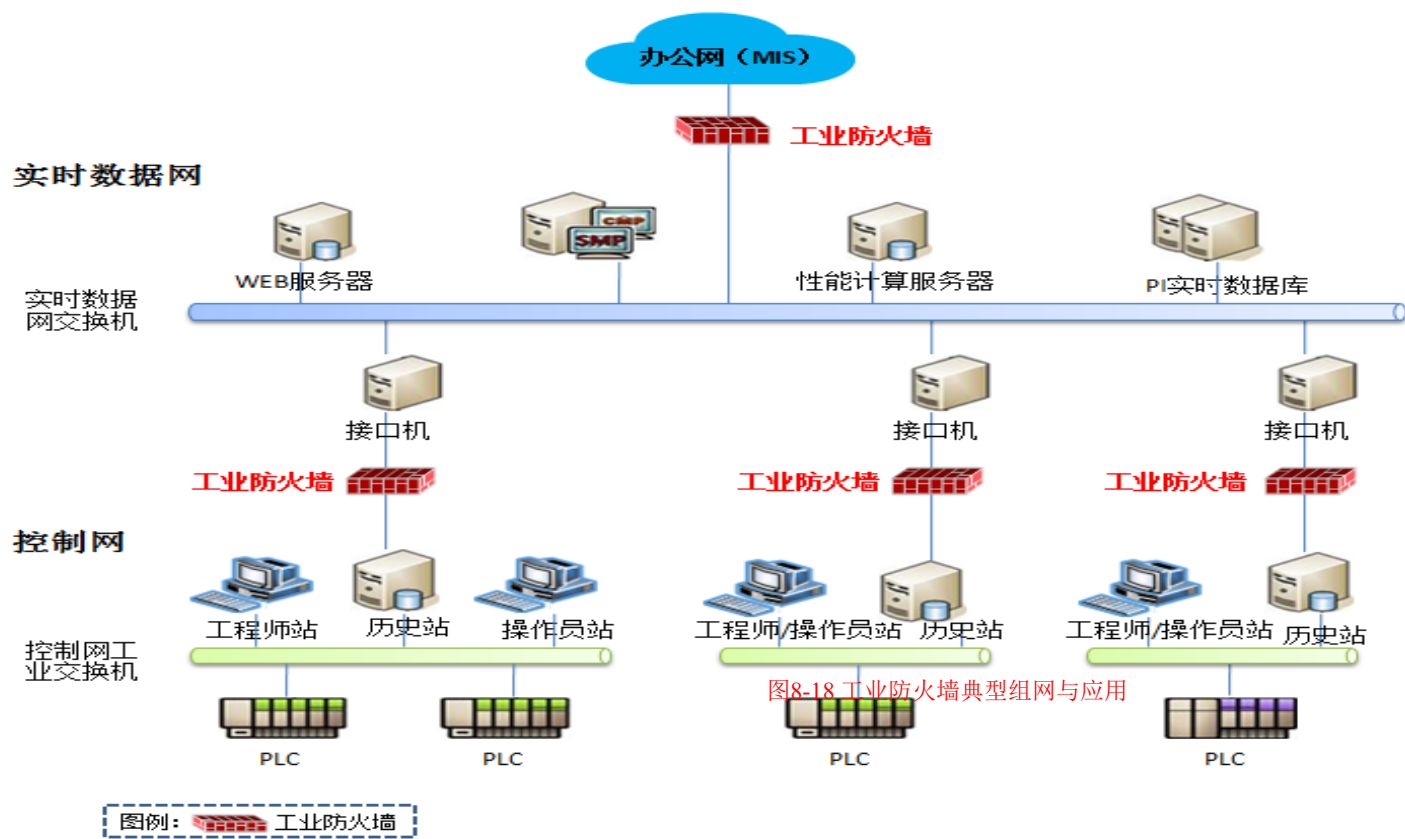


图8-18 工业防火墙典型组网与应用



8.4 实验8 国产工业控制防火墙应用

8.4.1 实验目的与要求

通过对国产亨通工业控制防火墙系统进行安全配置，通过具体操作，进一步加深理解防火墙的基本工作原理和基本概念，更好地掌握防火墙的配置和使用。

- 1) 理解防火墙的基本工作原理和基本概念。
- 2) 掌握亨通工业控制防火墙安全策略的配置



8.4 实验8 国产工业控制防火墙应用

8.4.2 实验内容和步骤

1. 策略配置。

策略规则实现了基于对象的管理。流量的类型、流量的源地址与目标地址以及行为构成策略规则的基本元素。登录防火墙系统，点击菜单栏“安全规则/策略配置”进入页面，可对策略实现增加、删除、修改和排序。

8.4 实验8 国产工业控制防火墙应用

8.4.2 实验内容和步骤

1. 策略配置。

亨通工控防火墙系统

系统状态

系统管理

网络配置

服务

安全规则

策略配置

攻击防护

IP/MAC绑定

网络扫描防护

白名单管理

日志管理

用户管理

高级功能

策略配置

新建

源安全域 请选择

目的安全域 请选择

查询

trust-untrust

默认: 行为(拒绝) 日志

启用	ID	描述	源地址	源MAC	目的地址	应用	生效时间	行为	操作
☒	1		Any	Any	Any	Any	无限制	ACCEPT	编辑 移动 删除

untrust-trust

默认: 行为(拒绝) 日志

启用	ID	描述	源地址	源MAC	目的地址	应用	生效时间	行为	操作
☒	2		Any	Any	Any	Any	无限制	ACCEPT	编辑 移动 删除

< 1 >

到第 1 页

确定

共 2 条

15 条/页

版权所有©2018 - 2020 江苏亨通工控安全研究院有限公司



8.4 实验8 国产工业控制防火墙应用

2. 策略添加。

点击菜单栏“安全规则/策略配置”选在页面右上角“新建”按钮（如图所示）跳转到添加策略界面。在此页面可完成相应策略的添加。

8.4 实验8 国产工业控制防火墙应用

1. 策略添加。



图8-20 新建策略



图8-21 策略配置

8.4 实验8 国产工业控制防火墙应用

3. MAC添加。

按照提示格式，填写MAC地址，不填代表Any。

源MAC

MAC 格式: XX:XX:XX:XX:XX:XX

字母A-F不区分大小写、数字0-9以及:组成。不填写或输入 any 表示不限制

图8-22 添加MAC

8.4 实验8 国产工业控制防火墙应用

4. IP添加。选择对应源安全域，然后点击“添加”按钮进入添加IP界面。

添加/修改源地址

Any ☐ Any

IP 添加

192.168.10.122 X

IP范围 添加

图8-23 添加地址界面

类型：选择本次添加IP的类型，any(任意地址可访问)，IP地址（填写单一IP），IP范围(对应的IP地址段)。

IP：填写对应IP地址、掩码以/(0-32)结束。（例192.168.1.1/32）

地址列表：显示已添加IP。

操作：执行删除操作。

完成：完成添加、跳转到上一界面。

取消：取消添加、跳转到上一界面。

8.4 实验8 国产工业控制防火墙应用

5. 应用添加。同样的方式选择目标安全域，以及添加目的IP地址。点击应用旁边的“添加”按钮跳转到添加应用界面。

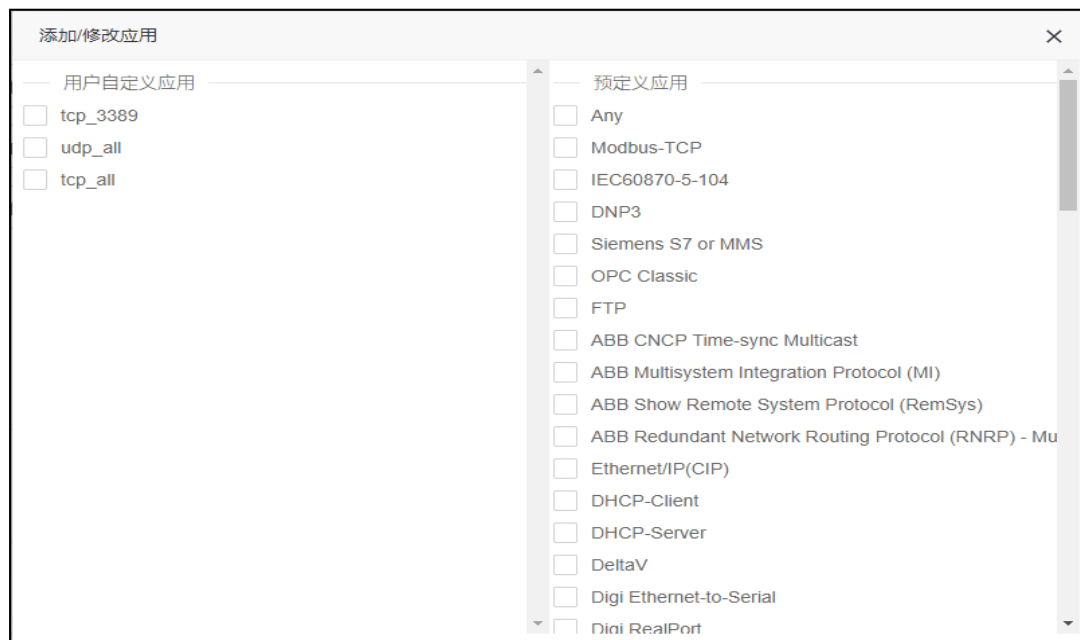


图8-24 应用选择界面

可用成员：包含系统预定义应用、预定义应用组、自定义应用、自定义应用组，单击完成添加。

组成员：已添加应用，单击可删除。

关闭：完成关于应用的编辑之后，点击按钮返回上级菜单。

8.4 实验8 国产工业控制防火墙应用

5. 应用添加。同样的方式选择目标安全域，以及添加目的IP地址。点击应用旁边的“添加”按钮跳转到添加应用界面。

生效时间选择

用户可以选择生效时间，分为3个种类，指定每天生效时间，每周生效时间，和指定具体时间段生效。



添加/修改生效时间

类型 ☒ 不限制 ☐ 每天 ☐ 每周 ☐ 时间段

图8-25 生效时间界面

8.4 实验8 国产工业控制防火墙应用

6. 其他。应用添加结束后需要对需要设置策略的行为、日志、描述进行选择。



DPI ☐ 启用/关闭

行为 ☒ 允许 ☐ 拒绝

日志 ☐ 日志

描述

图8-26 其他设置

DPI： 针对工业协议的深度解析，勾选可以设置策略白名单模板

行为： 防火墙针对此条策略的处理方式

日志： 是否打印本条策略产生日志（建议勾选）

描述： 对本条策略进行简单解释，方便管理

8.4 实验8 国产工业控制防火墙应用

7. 完成添加。全部配置完成后点击页面下方“添加”按钮完成策略添加，并返回上级菜单。

策略配置

新建策略

源MAC

MAC 格式: XX:XX:XX:XX:XX:XX

字母A-F不区分大小写、数字0-9以及:组成。不填写或输入 any 表示不限制

源安全域

请选择

源地址

192.168.10.122

添加/修改源地址

目的安全域

请选择

目的地址

Any

添加/修改目的地址

应用

添加/修改应用

生效时间

添加/修改生效时间

DPI

☐ 启用/关闭

行为

☒ 允许 ☐ 拒绝

日志

☐ 日志

描述

请输入描述,不超过256个字符

保存

图8-27完成策略添加界面

“十三五”国家重点出版规划
国家自然科学基金项目资助

上海市普通高校优秀教材奖
上海高校精品/优质在线课程

诚挚谢意！

网络安全技术及应用

国家智慧教育平台

国家智慧教育平台-上海精品/优质在线课程



网络安全技术

(第5版, 慕课微课版立体化)

